

# MODULE 1: INTRODUCTION TO COMPUTER SECURITY

## Contents

|                                       |    |
|---------------------------------------|----|
| Computer Security.....                | 1  |
| Security Approaches .....             | 2  |
| 1. Prevention Approach: .....         | 2  |
| 2. Detection Approach .....           | 3  |
| 3. Response Approach .....            | 4  |
| 4. Recovery Approach .....            | 4  |
| CIA Triad .....                       | 5  |
| 1. Confidentiality .....              | 5  |
| 2. Integrity .....                    | 6  |
| 3. Availability .....                 | 7  |
| Other Security Principles .....       | 7  |
| 1. Authentication .....               | 8  |
| 2. Authorization .....                | 8  |
| 3. Non-Repudiation.....               | 10 |
| 4. Accountability.....                | 10 |
| 5. Privacy .....                      | 10 |
| 6. Principle of Least Privilege ..... | 11 |
| 7. Auditing .....                     | 11 |

## Computer Security

Computer Security refers to the protection of computer systems, networks, programs, and data from unauthorized access, attacks, damage, or theft. It ensures that information and resources remain safe from cyber threats. **Main Objectives of Security**

- |                                 |                                         |
|---------------------------------|-----------------------------------------|
| 1. Protect data and information | 4. Maintain privacy and confidentiality |
| 2. Prevent unauthorized access  |                                         |
| 3. Ensure system reliability    | 5. Prevent data loss and cyber attacks  |

### Need for Security

With the growth of the internet and digital communication, computer systems face many threats such as hacking, malware, phishing, and data theft. **Reasons Why Security is Needed**

1. **Protection of Data:** Sensitive information like passwords, bank details, and personal records must be protected.
2. **Privacy Protection:** Users expect their personal information to remain private.
3. **Prevent Financial Loss:** Cyber-attacks can cause huge financial damage to organizations.
4. **Prevent Unauthorized Access:** Only authorized users should access systems and resources.
5. **Business Continuity:** Security ensures systems continue functioning without interruption.

6. **National Security:** Government and defence systems require strong security mechanisms.

## Security Approaches

Security approaches are the different methods and strategies used to protect computer systems, networks, and data from unauthorized access, attacks, and damage. No single security method is enough to provide complete protection. Therefore, organizations use multiple security approaches together to ensure better protection.

The major security approaches are:

- |               |             |
|---------------|-------------|
| 1. Prevention | 3. Response |
| 2. Detection  | 4. Recovery |

### 1. Prevention Approach:

The prevention approach focuses on stopping attacks before they happen. It is the first line of defense in computer security. The main objective of prevention is to block unauthorized users and reduce vulnerabilities in the system. **Features:**

- |                                     |                               |
|-------------------------------------|-------------------------------|
| • Stops attacks at an early stage   | • Strengthens system security |
| • Protects confidential information | • Minimizes risk              |
| • Reduces chances of data theft     |                               |

#### Techniques Used in Prevention

**A. Authentication:** Authentication verifies the identity of a user before allowing access. Example: When users log into Gmail using a password and OTP, authentication is performed. Common methods include:

- |                           |                        |
|---------------------------|------------------------|
| • Username and password   | • Fingerprint scanning |
| • OTP (One-Time Password) | • Face recognition     |

**B. Access Control:** Access control limits who can access specific files or resources. Different users receive different permissions. Example:

- |                             |                                              |
|-----------------------------|----------------------------------------------|
| • Students can view marks   | • Administrators can manage the whole system |
| • Teachers can modify marks |                                              |

**C. Encryption:** Encryption converts readable information (plaintext) into unreadable form (ciphertext). Only authorized users with the decryption key can read the data. Example: Online banking transactions use encryption to secure financial information.

**D. Firewall:** A firewall acts as a barrier between a trusted network and an untrusted network. It monitors and filters incoming and outgoing traffic. Functions:

- |                                |                              |
|--------------------------------|------------------------------|
| • Blocks malicious traffic     | • Protects internal networks |
| • Prevents unauthorized access |                              |

**E. Antivirus Software:** Antivirus software detects and removes malware such as viruses, worms, and trojans. Functions:

- |                            |                                 |
|----------------------------|---------------------------------|
| • Scans files and programs | • Provides real-time protection |
| • Removes infected files   |                                 |

Examples:

- Windows Defender
- Quick Heal
- Norton Antivirus

### **Advantages of Prevention Approach**

- Reduces chances of attacks
- Protects sensitive data
- Improves system reliability
- Prevents financial losses

### **Limitations**

- Cannot stop all attacks
- Requires regular updates
- Advanced attackers may bypass protection

## **2. Detection Approach**

The detection approach identifies attacks or suspicious activities occurring in a system or network. Even strong preventive measures may fail. Therefore, detection mechanisms are necessary to identify threats quickly. **Objectives**

- Identify attacks
- Monitor suspicious behavior
- Alert administrators
- Reduce damage

### **Techniques Used in Detection**

**A. Intrusion Detection System (IDS):** IDS monitors network traffic and system activities for malicious behavior. Example: If a user attempts multiple failed logins, IDS may detect a brute-force attack. Types:

1. Network-based IDS (NIDS)
2. Host-based IDS (HIDS)

Functions:

- Detects unusual activities
- Generates alerts
- Logs suspicious events

**B. Log Monitoring:** Systems maintain logs of user activities and events. Administrators analyze logs to detect abnormal behavior. Examples of logged information:

- Login attempts
- System errors
- File access
- Network activities

**C. Security Auditing:** Security auditing involves reviewing system security policies and activities. Purpose:

- Identify vulnerabilities
- Improve security
- Ensure compliance

**D. Malware Detection Tools:** Security software scans systems to identify malicious programs.

Functions:

- Detect viruses and spyware
- Monitor file behavior
- Identify suspicious applications

### **Advantages of Detection Approach**

- Quickly identifies attacks
- Helps prevent large-scale damage
- Improves monitoring capability

- Provides evidence for investigation

#### **Limitations**

- Cannot prevent attacks directly

- False alarms may occur
- Requires continuous monitoring

### 3. Response Approach

The response approach focuses on actions taken after detecting a security incident. The objective is to minimize damage and stop the attack from spreading. **Steps in Response Approach**

**A. Identification:** The organization identifies:

- Type of attack
- Affected systems
- Source of attack

**B. Containment:** Containment prevents the attack from spreading. Examples:

- Disconnect infected systems
- Block malicious IP addresses
- Disable compromised accounts

**C. Elimination:** The threat is removed from the system. Methods:

- Delete malware
- Patch vulnerabilities
- Remove unauthorized users

**D. Investigation:** Security experts analyze:

- How the attack occurred
- What damage was caused
- Which systems were affected

**E. Notification:** Organizations may inform:

- Users
- Customers
- Authorities
- Management

Especially in cases of data breaches.

#### **Advantages of Response Approach**

- Minimizes damage
- Controls attack spread
- Helps restore normal operations
- Improves future security planning

#### **Limitations**

- Attack may already have caused damage
- Requires skilled security teams
- Response delays may increase losses

### 4. Recovery Approach

Recovery is the process of restoring systems, networks, and data after an attack or failure. The main objective is to return the organization to normal working condition. **Recovery Techniques**

**A. Backup Restoration:** Data backups are used to restore lost or damaged information. Example: Recovering deleted company files from cloud backup. Types of backups:

- Full backup
- Incremental backup
- Differential backup

**B. Disaster Recovery Plan (DRP):** A disaster recovery plan is a structured plan to recover systems during emergencies. It includes:

- Recovery procedures
- Backup locations



- Emergency contacts
- System restoration steps

### C. System Repair and Reinstallation:

Damaged operating systems or software may need repair or reinstallation.

### D. Business Continuity Planning:

Ensures business operations continue even during attacks or failures. Example: Using backup servers when the main server fails.

### Advantages of Recovery Approach

- Restores lost data
- Reduces downtime
- Ensures business continuity
- Helps organizations recover quickly

### Limitations

- Recovery may take time
- Backup systems are costly
- Some data may still be lost

## Relationship Between Security Approaches

All four approaches work together to provide complete security.

| Approach   | Main Goal                      |
|------------|--------------------------------|
| Prevention | Stop attacks before they occur |
| Detection  | Identify attacks quickly       |
| Response   | Minimize damage during attacks |
| Recovery   | Restore systems after attacks  |

## CIA Triad

The CIA Triad is the fundamental model of Information Security. It consists of three major security principles:

1. Confidentiality
2. Integrity
3. Availability

The term “CIA” here does not refer to the intelligence agency. These three principles together help in designing secure computer systems, networks, and applications. The CIA Triad forms the foundation of Cryptography and Network Security.

### 1. Confidentiality

Confidentiality means protecting information from unauthorized access or disclosure. Only authorized users should be able to view sensitive data. It ensures privacy and secrecy of information.

#### Objectives of Confidentiality

- Prevent unauthorized access
- Protect private information
- Maintain secrecy of sensitive data
- Ensure data privacy
- Only account holders can access bank account details.
- Student marks should only be visible to authorized persons.
- Military secrets must remain confidential.

#### Examples

#### Methods Used to Achieve Confidentiality

1. **Encryption:** Encryption converts readable data (plaintext) into unreadable form (ciphertext). Only users with the correct decryption key can read the data. Example: HTTPS websites use encryption to secure communication.
2. **Authentication:** Authentication verifies the identity of users before access is granted. Examples: Passwords, OTP, Biometrics
3. **Access Control:** Access control restricts who can view or use information. Example: Employees may access only department-related files.
4. **Data Classification:** Data is categorized according to sensitivity.

|                     |                                                                                                           |
|---------------------|-----------------------------------------------------------------------------------------------------------|
| <b>Public</b>       | Information that can be freely shared without restrictions.                                               |
| <b>Private</b>      | Information intended for personal or limited use; not for general distribution.                           |
| <b>Confidential</b> | Sensitive information accessible only to authorized individuals; disclosure could cause harm.             |
| <b>Top Secret</b>   | Highly restricted information requiring maximum security clearance; disclosure could cause severe damage. |

### Advantages of Confidentiality

- Protects user privacy
- Prevents data theft
- sensitive information
- Maintains trust
- Secures

## 2. Integrity

Integrity means maintaining the accuracy, consistency, and correctness of data. Data should not be modified by unauthorized users. It ensures that information remains trustworthy. Objectives:

- |                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>• Prevent unauthorized modification</li> <li>• Maintain data accuracy</li> <li>• Ensure reliability of information</li> <li>• Protect against accidental changes</li> </ul> | <b>Examples</b> <ul style="list-style-type: none"> <li>• Bank transaction amounts should not be altered illegally.</li> <li>• Examination marks should remain accurate.</li> <li>• Medical records should not be modified without authorization</li> </ul> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### Methods Used to Achieve Integrity

1. **Hash Functions:** A hash function generates a fixed-size value called a hash or message digest. If data changes, the hash value also changes. Examples: SHA-256, MD5
2. **Digital Signatures:** verify: Data authenticity, Data integrity, Sender identity
3. **Checksums:** Checksums help detect errors during data transmission.
4. **Access Control:** Restricts unauthorized users from modifying files.

### Advantages of Integrity

- Ensures accurate information
- Maintains trustworthiness
- Prevents data corruption
- Supports reliable decision-making

### 3. Availability

Availability ensures that systems, services, and data are accessible whenever needed by authorized users. Systems should remain operational and functional. **Objectives:**

- Ensure continuous service
- Minimize downtime
- Provide reliable access
- Support business continuity

#### Examples

- Online banking services should be available 24/7.
- Hospital databases must remain accessible during emergencies.
- E-commerce websites should remain active during high traffic.

#### Methods Used to Achieve Availability

1. **Data Backup:** Copies of important data are stored for recovery purposes.
2. **Redundancy:** multiple systems or servers are used so that backup systems can operate if one fails.
3. **Disaster Recovery Plan:** A structured recovery plan helps restore services after failures.
4. **UPS (Uninterruptible Power Supply):** Provides backup power during electricity failures.
5. **Load Balancing:** Traffic is distributed across multiple servers to prevent overload.

#### Advantages of Availability

- Ensures uninterrupted service
- Reduces downtime
- business operations
- Improves user satisfaction
- Supports

#### Relationship Between the Three Principles

The three principles work together to provide complete information security.

| Principle       | Main Focus                        |
|-----------------|-----------------------------------|
| Confidentiality | Prevent unauthorized access       |
| Integrity       | Prevent unauthorized modification |
| Availability    | Ensure continuous access          |

#### Importance of CIA Triad

- Forms the foundation of cybersecurity
- Helps design secure systems
- Protects sensitive information
- Maintains user trust
- Ensures reliable system operations

### Other Security Principles

Apart from the CIA Triad, several additional principles are important for maintaining computer and network security. These principles ensure proper access control, accountability, trust, and secure communication. The important security principles are:

1. Authentication
2. Authorization
3. Non-Repudiation
4. Accountability
5. Privacy
6. Least Privilege
7. Auditing

# 1. Authentication

Authentication is the process of verifying the identity of a user, device, or system. It answers the question: “Who are you?” Only authenticated users are allowed to access the system.

## Types of Authentication

1. **Knowledge-Based Authentication:** Based on something the user knows. Examples: Password, PIN, Security questions
2. **Possession-Based Authentication:** Based on something the user possesses. Examples: Smart card, ATM card, Mobile OTP
3. **Biometric Authentication:** Based on physical characteristics. Examples: Fingerprint, Retina scan, Face recognition
4. **Multi-Factor Authentication (MFA):** MFA combines multiple authentication methods for better security. Example: Password + OTP

## Importance of Authentication

- Prevents unauthorized access
- Protects confidential data
- Ensures system security
- Verifies user identity

# 2. Authorization

Authorization determines what actions or resources an authenticated user can access. It answers the question: “What are you allowed to do?” **Example:** In a college management system:

- Students can view marks
- Teachers can update marks
- Admin can manage the database

## Types of Authorization

### A. Static & Structural Models

These models determine permissions based on identity, organizational structure, or explicit assignments.

1. **User-Based Authorization** Permissions are tied directly to an individual user account (e.g., "User *Alice* can read file X").
  - **How it works:** An Access Control List (ACL) explicitly maps individuals to resources.
  - **Pros/Cons:** Highly precise for a few users, but becomes a maintenance nightmare as an organization grows.
2. **Group-Based Authorization:** Users are pooled into collective "groups" (e.g., *Engineering*, *Marketing*), and permissions are granted to the group as a whole.
  - **How it works:** Instead of managing 50 individual engineers, you grant read/write access to the "Dev-Team" group.

- **Pros/Cons:** Simplifies management significantly compared to user-based control, but lacks granular context.
3. **Role-Based Authorization (RBAC):** Often confused with Group-Based control, RBAC abstracts access one step further by mapping permissions to a **job function or role** (e.g., *Admin, Editor, Billing Manager*), rather than just a department pool.
    - **How it works:** Roles are defined by business operations. Users inherit permissions by being assigned to a role.

## B. Policy & Dynamic Models (What the context is)

These models move away from static roles and evaluate access requests in real-time based on variable characteristics and environmental factors.

1. **Attribute-Based Authorization (ABAC):** A highly flexible, next-generation model that evaluates policies using a combination of dynamic attributes.
  - **How it works:** It checks attributes across four categories:
    - **Subject:** (e.g., clearance level, job title).
    - **Resource:** (e.g., file type, department label, classification).
    - **Action:** (e.g., read, write, delete).
    - **Environment:** (e.g., current time, location).
  - **Example:** "Allow access if Subject.Title = 'Manager' and Resource.Type = 'Financial' and Environment.Time = 'Business Hours'."
2. **Context-Based Authorization:** This is a specific subset or implementation focus of ABAC. It ignores *who* you are for a moment and strictly evaluates the **transactional context** of the request.
  - **How it works:** It acts as a security guard analyzing external risks.
  - **Example:** Even if an Admin has the correct role, Context-Based systems will deny access if they log in from an unrecognized IP address, an unmanaged device, or a country where the company does not operate.

## C. High-Security & Administrative Models (Who governs it)

These models define who has the authority to change security permissions in the first place.

1. **Discretionary Access Control (DAC):** In this model, the **creator or owner** of the resource has total discretion over who gets access.
  - **How it works:** The data owner can pass permissions to other users at will.
  - **Example:** The standard file system on your computer (NTFS/ext4) or a Google Doc where you choose to share a link with "Viewer" or "Editor" privileges.
  - **Risk:** High security risk, as a user could accidentally share sensitive data with the wrong person.

2. **Mandatory Access Control (MAC):** The most rigid and secure model, where access is centrally controlled by a system administrator or strict security policy. Individual users **cannot** change permissions, even on files they created.
- **How it works:** Resources and users are assigned security labels (e.g., *Unclassified*, *Secret*, *Top Secret*). Access is granted only if the user's clearance level matches or exceeds the resource's classification.
  - **Example:** Military computer networks or highly secure operating systems like SELinux.

### Importance of Authorization

- Prevents misuse of resources
- Limits access rights
- Improves security management

## 3. Non-Repudiation

Non-repudiation ensures that a sender cannot deny sending a message and a receiver cannot deny receiving it. This principle provides proof of communication. **Example:** In online banking, digital signatures prove that a customer initiated a transaction. **Achieved Using**

- Digital signatures
- Encryption
- Time stamps

### Importance:

- Prevents denial of actions
- Provides legal evidence
- Ensures trust in communication

## 4. Accountability

Accountability ensures that user activities can be tracked and monitored. Every action performed in the system should be traceable. **Example:** If a user deletes important files, administrators can identify who performed the action. **Achieved Using**

- Audit logs
- User activity records
- Monitoring systems

### Importance

- Discourages malicious activities
- Helps investigations
- Improves transparency

## 5. Privacy

Privacy ensures personal and sensitive information is protected from unauthorized disclosure. Users should control how their information is collected and used. **Examples of Private Information:** Aadhaar number, Bank details, Medical records, Personal messages

### Methods to Ensure Privacy

- Encryption
- Privacy policies
- Access restrictions

### Importance

- Protects user rights

- Prevents identity theft
- Maintains trust

## 6. Principle of Least Privilege

This principle states that users should receive only the minimum permissions necessary to perform their tasks. **Example:** A normal employee should not have administrator privileges.

### Advantages

- Reduces security risks
- Prevents accidental damage
- Limits attack impact

## 7. Auditing

Auditing is the process of reviewing and analysing system activities and security policies.

### Objectives

- Detect vulnerabilities
- Monitor policy compliance
- Identify suspicious activities

### Types of Auditing

**A. Internal Audit:** Conducted within the organization.

**B. External Audit:** Conducted by outside experts or organizations.

### Importance of Auditing

- Improves security
- Detects weaknesses
- Ensures regulatory compliance

# MODULE 2: CRYPTOGRAPHY

## Contents

|                                                          |   |
|----------------------------------------------------------|---|
| Cryptography .....                                       | 1 |
| Transformation of plaintext into ciphertext .....        | 1 |
| 1. Substitution Techniques .....                         | 1 |
| 2. Transposition Techniques .....                        | 6 |
| Cryptographic Key .....                                  | 8 |
| The Relationship Between Size, Range, and Security ..... | 9 |
| Types of Cryptography .....                              | 9 |

## Cryptography

**Cryptography** is the science and practice of securing information and communications through the use of codes, protecting it from unauthorized access or alteration. At its core, it transforms human-readable data (**plaintext**) into an unreadable, scrambled format (**ciphertext**) using mathematical algorithms and a secret key. Only someone with the correct key can reverse the process to read the original message.

- **Plaintext:** Original message
- **Ciphertext:** Encrypted message
- **Encryption:** Plaintext → Ciphertext
- **Decryption:** Ciphertext → Plaintext
- **Key:** Secret value used in encryption/decryption

**Key space** = total number of possible keys. Example: 56-bit key →  $2^{56}$  possibilities. Larger key space → More secure against brute force.

## Transformation of plaintext into ciphertext

### 1. Substitution Techniques

Substitution ciphers replace plaintext characters with other characters, numbers, or symbols while keeping their positions unchanged. The actual letters are substituted according to a specific rule or key. These techniques are among the oldest methods used in classical cryptography. Substitution techniques are categorized based on:

- Number of alphabets used
- Number of letters encrypted at a time

The major substitution techniques are:

1. Caesar/Shift Cipher
2. Monoalphabetic Cipher



3. Playfair Cipher
4. Hill Cipher

## 5. Vigenère Cipher

1. **Caesar Cipher (Shift Cipher):** The Caesar Cipher is one of the oldest and simplest encryption techniques. It was used by the Roman emperor Julius Caesar for secure military communication. In this cipher, each letter in the plaintext is shifted by a fixed number of positions in the alphabet.

**Encryption Formula:**  $C=(P+K) \bmod 26$

C= Cipher letter

P=Plaintext letter

K=Shift Key

**Example**

Plaintext Ciphertext(shift=3)

HELLO KHOOR

### Advantages

- Very simple to implement
- Fast encryption and decryption
- Useful for learning cryptography basics

### Weaknesses

- Extremely weak security
- Only 25 possible keys exist
- Easily broken using brute force attack

2. **Monoalphabetic Cipher (Arbitrary Substitution Cipher):** In a Monoalphabetic Cipher, each plaintext letter maps to a unique ciphertext letter. Unlike Caesar Cipher, the substitution is completely random rather than using a fixed shift. A single substitution rule is used throughout the message.

### How It Works

Example mapping:

| Plain Letter | Cipher Letter |
|--------------|---------------|
| A            | Q             |
| B            | X             |
| C            | M             |
| D            | P             |
| ...          | ...           |

The key is a complete permutation of the alphabet.

**Example**

Plaintext: CAT

Using mapping:

$C \rightarrow M$

$A \rightarrow Q$

$T \rightarrow L$

Ciphertext: MQL

### Advantages

- More secure than Caesar Cipher
- Large number of possible keys
- Harder to guess manually

analysis because letter frequencies remain unchanged. For example:

- E is the most common English letter
- T and A are also frequent

Attackers can analyze ciphertext frequency to guess mappings.

### Weaknesses

Although the key space is very large:  $26! \approx 4 \times 10^{26}$ . It is still vulnerable to frequency

3. **Playfair Cipher (Polygraphic Substitution Cipher):** The Playfair Cipher encrypts pairs of letters (digraphs) instead of single letters. It was the first practical digraph substitution cipher and

provides better security than monoalphabetic ciphers. For each occurrence of a letter in plaintext, while converting it to ciphertext, each time it will be different letter.

**How It Works:** A  $5 \times 5$  matrix is generated using a keyword. (26 letters,  $5 \times 5$  and I/J together in 1 cell)

### Example

**Keyword:** MONARCHY

|   |   |   |     |   |
|---|---|---|-----|---|
| M | O | N | A   | R |
| C | H | Y | B   | D |
| E | F | G | I/J | K |
| L | P | Q | S   | T |
| U | V | W | X   | Z |

### Encryption Rules

1. Digrams.
2. Repeating Letters - Filler letter.
3. Same Column |  $\downarrow$  | Wrap around.
4. Same row |  $\rightarrow$  | Wrap around.
5. Rectangle |  $\rightleftarrows$  | Swap

**Rule 1: Same Row:** go right

**Rule 2: Same Column:** go down

**Rule 3: Rectangle Rule:** If letters form a rectangle: Replace each letter with the letter in the same row but opposite corner column.

### Example

Plaintext: attack

Digrams: at ta ck

Plaintext: neso academy

Digrams: ne so ac ad em yx

Plaintext: balloon

Digrams: ba ll oo n

Digrams: ba lx lo on

### Example:

1) Plaintext: attack

|            |    |    |    |
|------------|----|----|----|
| Digrams    | at | ta | ck |
| Ciphertext | rs | sr | Dk |

(here we used rectangle rule)

|   |   |   |     |   |
|---|---|---|-----|---|
| M | O | N | A   | R |
| C | H | Y | B   | D |
| E | F | G | I/J | K |
| L | P | Q | S   | T |
| U | V | W | X   | Z |

|   |   |   |     |   |
|---|---|---|-----|---|
| M | O | N | A   | R |
| C | H | Y | B   | D |
| E | F | G | I/J | K |
| L | P | Q | S   | T |
| U | V | W | X   | Z |

**Ciphertext:** rssrdk

② plaintext: mosque

|    |    |    |
|----|----|----|
| mo | sq | ue |
| on | ts | ml |

① mo in same row,  $\therefore$  go right for both  
 $m \rightarrow o$  ,  $o \rightarrow n$

② Same for sq  $\rightarrow$  ts

③ ue in same row, go down for both.  
 $u \rightarrow m$   $e \rightarrow l$

Ciphertext: ontsml

|   |   |   |     |   |
|---|---|---|-----|---|
| M | O | N | A   | R |
| C | H | Y | B   | D |
| E | F | G | I/J | K |
| L | P | Q | S   | T |
| U | V | W | X   | Z |

Question: Encrypt the message "Hide the gold under the carpet" using the keyword "Neso Academy"

|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| N | E | S | O | A | H | I | D | E | T | H | E | G | O | L | D | U | N | D | E | R | T | H | E | C | A | R | P | E | T | X |
| C | D | M | Y | B | I | K | G | D | Q | K | D | P | N | R | C | V | E | C | O | P | Q | K | N | O | O | T | V | O | R | Z |
| F | G | H | I | J | K |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
| L | P | Q | R | T |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
| U | V | W | X | Z |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |

#### Advantages

- Stronger than simple substitution ciphers
- Hides single-letter frequency patterns
- More secure than Caesar and Monoalphabetic ciphers

#### Weaknesses

- Complex implementation
- Still vulnerable to cryptanalysis
- Repeated digraph patterns may reveal information

#### 4. Hill Cipher (Polygraphic Matrix Cipher)

The Hill Cipher uses linear algebra and matrix multiplication for encryption. It is a multi-letter cipher that is it encrypts groups of letters simultaneously rather than individual letters (digraph, trigraph or polygraph). It is mathematically stronger than earlier classical ciphers.

**Encryption Formula**  $C = K \times P \pmod{26}$

**Decryption Formula**  $P = K^{-1} \times C \pmod{26}$

$$K^{-1} = (|K|^{-1}) \begin{bmatrix} d & -b \\ -c & a \end{bmatrix} \pmod{26}$$

$|K|^{-1}$  is the multiplicative inverse of determinant modulo 26.

#### Example

Using Hill Cipher Encrypt & Decrypt the Plaintext "HELP" using  $K = \begin{pmatrix} 3 & 3 \\ 2 & 5 \end{pmatrix}$

Ans)  $H = 7$   $E = 4$   $L = 11$   $P = 15$

$P_1 = \begin{pmatrix} 7 \\ 4 \end{pmatrix}$   $P_2 = \begin{pmatrix} 11 \\ 15 \end{pmatrix}$

$$[C_i \ C_j] = (K \cdot P) \pmod{26}$$

$$\begin{pmatrix} C_1 \\ C_2 \end{pmatrix} = \begin{pmatrix} 3 & 3 \\ 2 & 5 \end{pmatrix} \begin{pmatrix} 7 \\ 4 \end{pmatrix} \pmod{26} = \begin{pmatrix} 33 \\ 34 \end{pmatrix} \pmod{26} = \begin{pmatrix} 7 \\ 8 \end{pmatrix} = \begin{pmatrix} H \\ I \end{pmatrix}$$

$$\begin{pmatrix} C_3 \\ C_4 \end{pmatrix} = \begin{pmatrix} 3 & 3 \\ 2 & 5 \end{pmatrix} \begin{pmatrix} 11 \\ 15 \end{pmatrix} \pmod{26} = \begin{pmatrix} 78 \\ 97 \end{pmatrix} \pmod{26} = \begin{pmatrix} 0 \\ 19 \end{pmatrix} = \begin{pmatrix} A \\ T \end{pmatrix}$$

$\therefore$  Ciphertext = HIAT

Decryption

$$K^{-1} = 9^{-1} \begin{pmatrix} 5 & -3 \\ -2 & 3 \end{pmatrix} \mod 26 \left[ \begin{array}{l} 9^{-1} \mod 26 = 3 \\ \text{or } (9 \times 3) \mod 26 = 1 \\ \hline -x \mod p = (-x + p) \end{array} \right]$$

$$= 3 \begin{pmatrix} 5 & 23 \\ 24 & 3 \end{pmatrix} \mod 26$$

$$= \begin{pmatrix} 15 & 69 \\ 72 & 9 \end{pmatrix} \mod 26 = \begin{pmatrix} 15 & 17 \\ 20 & 9 \end{pmatrix}$$

Ciphertext = H I A T

$$C_1 = \begin{pmatrix} H \\ I \end{pmatrix} = \begin{pmatrix} 7 \\ 8 \end{pmatrix}$$

$$C_2 = \begin{pmatrix} A \\ T \end{pmatrix} = \begin{pmatrix} 0 \\ 19 \end{pmatrix}$$

$$\therefore P_1 = \begin{pmatrix} 15 & 17 \\ 20 & 9 \end{pmatrix} \begin{pmatrix} 7 \\ 8 \end{pmatrix} = \begin{pmatrix} 241 \\ 212 \end{pmatrix} \mod 26 = \begin{pmatrix} 7 \\ 4 \end{pmatrix} = \begin{pmatrix} H \\ E \end{pmatrix}$$

$$P_2 = \begin{pmatrix} 15 & 17 \\ 20 & 9 \end{pmatrix} \begin{pmatrix} 0 \\ 19 \end{pmatrix} \mod 26 = \begin{pmatrix} 323 \\ 171 \end{pmatrix} \mod 26 = \begin{pmatrix} 11 \\ 15 \end{pmatrix} = \begin{pmatrix} L \\ P \end{pmatrix}$$

$$\therefore \text{Plaintext} = \begin{pmatrix} H & E & L & P \end{pmatrix}$$

#### Advantages

- Stronger mathematical security
- Encrypts multiple letters together
- Provides good diffusion

#### Weaknesses

- Complex calculations
- Requires matrix operations
- Vulnerable to known-plaintext attacks if enough plaintext-ciphertext pairs are known

**5. Polyalphabetic Cipher:** A Polyalphabetic Cipher uses multiple substitution alphabets instead of a single alphabet. This makes it more secure than monoalphabetic ciphers because the same plaintext letter can be encrypted into different ciphertext letters at different positions. The most famous polyalphabetic cipher is the **Vigenère Cipher**.

**Vigenère Cipher:** The Vigenère Cipher encrypts text using a keyword. Each letter of the keyword determines how much the plaintext letter is shifted. The Vigenère Cipher uses multiple Caesar ciphers based on a keyword. It is called a polyalphabetic cipher because different alphabets are used during encryption. This makes it more secure than simple substitution methods.

**How It Works:** A keyword is repeated until it matches the plaintext length. Each keyword letter determines the shift amount.

|                           |                             |
|---------------------------|-----------------------------|
| <b>Encryption Formula</b> | $C_i = (P_i + K_i) \mod 26$ |
| <b>Decryption Formula</b> | $P_i = (C_i - K_i) \mod 26$ |

Example

Encrypt & decrypt. PT: HELLO Key: KEY

Encryption

|     |   |   |   |   |   |   |    |   |    |    |    |
|-----|---|---|---|---|---|---|----|---|----|----|----|
| PT  | H | E | L | L | O | → | 7  | 4 | 11 | 11 | 14 |
| Key | K | E | Y | K | E | → | 10 | 4 | 24 | 10 | 4  |
| CT  | R | I | J | V | S | ← | 17 | 8 | 9  | 21 | 18 |

$CT = (K + P) \bmod 26$  [CT: RIJSVS]

Decryption

|     |    |   |     |    |    |
|-----|----|---|-----|----|----|
| CT  | 17 | 8 | 9   | 21 | 18 |
| Key | 10 | 4 | 24  | 10 | 4  |
| PT  | 7  | 4 | -15 | 11 | 14 |

= 11

[PT: HELLO]

### Advantages

- More secure than Caesar Cipher
- Reduces effectiveness of frequency analysis
- Uses multiple substitution alphabets

### Weaknesses

- If key length is discovered, cipher becomes weak
- Vulnerable to Kasiski examination
- Repeating keywords reduce security

## 2. Transposition Techniques

Transposition ciphers do not replace characters. Instead, they apply some sort of permutations on the plaintext letters that is rearrange the positions of characters according to a specific rule. The letters remain unchanged, but their order changes.

- 1. Rail Fence Cipher (Zig-Zag Cipher):** The Rail Fence Cipher is the simplest transposition cipher. Characters are written diagonally across multiple rows called rails and then read row by row.

### How It Works

Example: Encrypting DEFENDTHEWALL using 3 rails:

Plaintext

|                         |          |
|-------------------------|----------|
| D . . . N . . . W . . . | → DNNW   |
| . E . E . D . H . A . L | → EEDHAL |
| . . F . . . T . . . L . | → FTL    |

Ciphertext: DNNWEEDHALFTL

### Advantages

- Simple and fast
- Easy implementation
- Good for basic encryption

### Weaknesses

- Weak security
- Easily broken by pattern recognition
- Not suitable for modern security

## Rail Fence Technique

**Plaintext** : neso academy is the best.

**Depth** : 2

|   |   |   |   |   |   |   |   |   |   |   |
|---|---|---|---|---|---|---|---|---|---|---|
| n | s | a | a | e | y | s | h | b | s |   |
|   | e | o | c | d | m | i | t | e | e | t |

**Ciphertext** : NSAAEYSHBS

**2. Row Column Transposition Cipher:** The Row Column Transposition Cipher rearranges plaintext using columns and a keyword. Plaintext is written row by row into a table, and columns are read according to the alphabetical order of the keyword. Example:

Plaintext: ATTACKATDAWN

Keyword: SECRET

Assign column order alphabetically: S(5) E(2)

C(1) R(4) E(3) T(6)

Arrange plaintext in rows:

| S (5) | E (2) | C (1) | R (4) | E (3) | T (6) |
|-------|-------|-------|-------|-------|-------|
| A     | T     | T     | A     | C     | K     |
| A     | T     | D     | A     | W     | N     |

Columns are read according to numerical order.

Ciphertext: TDTTCWAAAANK

### Advantages

- Better security than Rail Fence Cipher
- Harder to detect patterns
- More complex arrangement

### Weaknesses

- Still vulnerable to cryptanalysis
- Long messages may reveal patterns
- Not secure against modern attacks

| Basis                         | Substitution Techniques                                       | Transposition Techniques                         |
|-------------------------------|---------------------------------------------------------------|--------------------------------------------------|
| <b>Definition</b>             | Replaces plaintext characters with other characters/symbols   | Rearranges the positions of plaintext characters |
| <b>Main Idea</b>              | Character substitution                                        | Character permutation                            |
| <b>Security Basis</b>         | Hides letter identity                                         | Hides letter position                            |
| <b>Encryption Method</b>      | Each letter mapped to another letter                          | Letters shuffled according to a pattern          |
| <b>Decryption Method</b>      | Reverse substitution used                                     | Reverse rearrangement used                       |
| <b>Example Techniques</b>     | Caesar Cipher, Playfair Cipher, Hill Cipher, Vigenère Cipher  | Rail Fence Cipher, Columnar Transposition Cipher |
| <b>Mathematical Operation</b> | Uses substitution rules/modular arithmetic, matrix operations | Uses permutations and positioning                |
| <b>Vulnerability</b>          | Vulnerable to frequency analysis                              | Vulnerable to anagram analysis                   |
| <b>Key Usage</b>              | Key decides substitution mapping                              | Key decides rearrangement order                  |



|                     |                                         |                                                      |
|---------------------|-----------------------------------------|------------------------------------------------------|
| <b>Modern Usage</b> | Basis of many modern encryption systems | Often combined with substitution for better security |
|---------------------|-----------------------------------------|------------------------------------------------------|

# Cryptographic Key

A **cryptographic key** is a piece of information—typically a string of random characters, numbers, or bits—used by a cryptographic algorithm to transform readable data (**plaintext**) into an unreadable format (**ciphertext**), or vice versa. Without the key, the algorithm is just a useless machine. The key acts as the unique passcode that configures the mathematical operations of the algorithm for a specific session or user.

**Kerckhoffs's Principle:** In cryptography, the security of any encryption algorithm does not rely on keeping the mathematical formula a secret—it relies entirely on keeping the **Key** a secret. This principle is known as **Kerckhoffs's Principle**.

**Key Size (Bit Length):** refers to the length of the key measured in **bits**. It is the most critical factor determining how resistant an algorithm is to a brute-force attack (where an attacker tries every possible key combination).

- **Symmetric Key Sizes (e.g., AES):** Typically range from **128 bits** to **256 bits**. Because symmetric ciphers use direct mathematical scrambling, relatively short keys provide massive security.
- **Asymmetric Key Sizes (e.g., RSA):** Typically range from **2048 bits** to **4096 bits**. They require much larger key sizes because they rely on specific mathematical vulnerabilities (like the difficulty of factoring giant prime numbers).

**Key Range (Key Space):** **Key Range** is the total number of unique, possible keys that can be generated at a specific key size. If a key is  $n$  bits long, it is a binary string. Therefore, the key range is determined exponentially:  $2^n$

**The Power of Exponential Growth:** Every single bit you add to a key size **doubles** the size of the key range, making it twice as hard to crack. To see how drastically this scales, let's look at a comparative matrix:

| Key Size (n)                         | Key Range (Total Possible Keys) | Security Status against Brute-Force                                                                                           |
|--------------------------------------|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>8 bits</b>                        | $2^8$                           | Cracked in microseconds.                                                                                                      |
| <b>56 bits</b> (Old DES standard)    | $2^{56}$                        | Broken in 1998 in under 3 days; completely insecure today.                                                                    |
| <b>128 bits</b> (Standard AES)       | $2^{128}$                       | <b>Secure.</b> Would take supercomputers billions of years to brute-force.                                                    |
| <b>256 bits</b> (Military-grade AES) | $2^{256}$                       | <b>Impenetrable.</b> The number of combinations approaches the number of atoms in the observable universe. Quantum-resistant. |

# The Relationship Between Size, Range, and Security

A large key size guarantees a massive key range, but it only ensures security if the algorithm satisfies **Entropy (Randomness)**.

- **The Trap of Weak Key Generation:** If an algorithm uses a 256-bit key size ( $2^{256}$  range), but the software generating the key has a bug that only picks keys starting with twelve zeros, the *actual* effective key range shrinks drastically. Attackers can ignore the rest of the key space and break it instantly.
- **The Performance Trade-Off:** Larger keys require more CPU processing cycles and battery power to encrypt and decrypt data. Cryptographers always balance security requirements against computational efficiency (which is why AES-128 is still widely used over AES-256 for standard web traffic).

## Types of Cryptography

### 1. Symmetric Key Cryptography

- Symmetric key cryptography is a type of encryption where the same key is used for both encryption and decryption.
- The sender and receiver must share the secret key securely before communication.
- Extremely fast and computationally efficient. It is designed to handle massive volumes of data (like streaming video, hard drive encryption, or database storage).
- **The Key Distribution Problem:** The biggest vulnerability of symmetric cryptography is *how* to safely share the secret key. If a hacker intercepts the key while A is sending it to b, the entire system is instantly compromised.
- Examples: AES, DES, Blowfish, RC4
- It is mainly used in: File encryption, Disk encryption, VPNs, Database security

Plaintext + Secret Key  $\rightarrow$  Ciphertext

Ciphertext + Same Secret Key  $\rightarrow$  Plaintext

### 2. Asymmetric Key Cryptography

- Asymmetric key cryptography uses two different keys: Public Key & Private Key
- The public key is used for encryption, and the private key is used for decryption.
- The public key can be shared openly, while the private key is kept secret.
- **Speed:** Highly complex and computationally heavy. It relies on advanced modular mathematics (like factoring massive prime numbers or calculating elliptic curves) and is much slower than symmetric encryption.
- **Solves the Key Problem:** No secret keys ever need to be exchanged over an insecure network. It is more secure for communication and key exchange
- Examples: RSA, ECC, Diffie-Hellman, ElGamal
- It is mainly used in: HTTPS/SSL, Digital signatures, Online banking, Secure email systems

Plaintext + Public Key  $\rightarrow$  Ciphertext



Ciphertext + Private Key → Plaintext

| <b>Feature</b>          | <b>Symmetric/ Private/ Secret/ Common Key Cryptography</b>                | <b>Asymmetric Key Cryptography</b>                                             |
|-------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| <b>Number of keys</b>   | One key (same for encryption & decryption)                                | Two keys (Public key + Private key)                                            |
| <b>Speed</b>            | Fast                                                                      | Slow (computationally expensive)                                               |
| <b>Key distribution</b> | Difficult and insecure over network                                       | Easy (public key can be shared openly)                                         |
| <b>Scalability</b>      | Poor (n users need $n(n-1)/2$ keys)                                       | Good (each user needs only one key pair)                                       |
| <b>Processing power</b> | Low                                                                       | High                                                                           |
| <b>Typical key size</b> | Small (128, 256 bits)                                                     | Large (1024, 2048, 4096 bits)                                                  |
| <b>Used for</b>         | Bulk data encryption                                                      | Key exchange, digital signatures, authentication                               |
| <b>Examples</b>         | AES – Advanced Encryption Standard, DES – Data Encryption Standard, 3-DES | RSA – Rivest–Shamir–Adleman, Diffie–Hellman (DH) – Diffie–Hellman Key Exchange |

# MODULE 3.1: SYMMETRIC KEY ALGORITHM

## Contents

|                                          |   |
|------------------------------------------|---|
| Symmetric Key Algorithm.....             | 1 |
| Types of Symmetric Key Algorithms .....  | 1 |
| Modes of Operation in Block Cipher ..... | 2 |
| Confusion and Diffusion .....            | 3 |
| Confusion .....                          | 3 |
| Diffusion .....                          | 4 |
| Stream Cipher vs. Block Cipher .....     | 5 |
| Stream Ciphers .....                     | 5 |
| Block Ciphers .....                      | 6 |
| The Feistel Cipher Structure .....       | 7 |

## Symmetric Key Algorithm

- A Symmetric Key Algorithm is an encryption technique where the same secret key is used for both encryption and decryption of data.
- The sender encrypts the plaintext using a secret key, and the receiver uses the same key to decrypt the ciphertext back into plaintext.
- It is called “symmetric” because the same key is shared between communicating parties.

### Overview of Symmetric Key Cryptography

Symmetric key cryptography is one of the oldest and fastest encryption methods.

It provides:

- Confidentiality of data
- Fast encryption and decryption
- Efficient processing for large files and networks

However, the major challenge is secure key distribution because both sender and receiver must know the same secret key.

### Characteristics

1. Uses a single shared key
2. Faster than asymmetric encryption
3. Suitable for bulk data encryption
4. Requires secure key sharing
5. Less computationally expensive

## Types of Symmetric Key Algorithms

Symmetric algorithms are mainly divided into two categories:

### 1. **Block Cipher:** A Block Cipher encrypts data in fixed-size blocks. Example: AES, DES, Blowfish.

Suppose block size is 64 bits:

- Plaintext is divided into 64-bit blocks
- Each block is encrypted separately

### Features

- More secure
- Used in modern systems
- Supports different modes of operation

**2. Stream Cipher:** A Stream Cipher encrypts data one bit or one byte at a time. Example: RC4

#### Features

- Faster for continuous data streams
- Used in wireless communication
- Suitable for real-time applications

## Modes of Operation in Block Cipher

Block ciphers use different modes to encrypt large amounts of data.

**1. ECB (Electronic Code Book):** Each plaintext block is encrypted independently. **Formula**

$$C_i = E_K(P_i)$$

#### Advantages

- Simple
- Fast

#### Disadvantages

- Less secure
- Identical plaintext blocks produce identical ciphertext blocks

**2. CBC (Cipher Block Chaining):** Each plaintext block is XORed with previous ciphertext block before encryption. **Formula**

$$C_i = E_K(P_i \oplus C_{i-1})$$

#### Advantages

- More secure than ECB
- Hides data patterns

#### Disadvantages

- Slower due to chaining

**3. CFB (Cipher Feedback):** Converts block cipher into stream cipher. **Features**

- Encrypts smaller units
- Useful in network communication

**4. OFB (Output Feedback):** Uses previous output for next encryption process. **Features**

- Error propagation is low
- Suitable for noisy channels

**5. CTR (Counter Mode):** Uses counter values combined with key for encryption. **Features**

- Very fast
- Supports parallel processing
- Highly efficient

| Mode | Full Form             | Main Trick / Property                       | Pattern Visibility | Parallel Processing             | Error Propagation                     | IV Needed           | Speed     |
|------|-----------------------|---------------------------------------------|--------------------|---------------------------------|---------------------------------------|---------------------|-----------|
| ECB  | Electronic Code Book  | "Same plaintext → Same ciphertext"          | Visible            | Yes                             | Only one block affected               | No                  | Fast      |
| CBC  | Cipher Block Chaining | "Each block depends on previous ciphertext" | Hidden             | Encryption: No, Decryption: Yes | Error affects current + next block    | Yes                 | Moderate  |
| CFB  | Cipher Feedback       | "Turns block cipher into stream cipher"     | Hidden             | No                              | Error propagates for some bits/blocks | Yes                 | Moderate  |
| OFB  | Output Feedback       | "Key stream generated independently"        | Hidden             | No                              | No error propagation                  | Yes                 | Fast      |
| CTR  | Counter Mode          | "Uses counter values instead of chaining"   | Hidden             | Yes                             | Only affected block changes           | Yes (Nonce/Counter) | Very Fast |

### Advantages

1. Fast encryption and decryption
2. Efficient for large data
3. Requires less computational power
4. Easy implementation

### Disadvantages

1. Key distribution problem
2. Less secure for communication over public networks
3. If key is leaked, entire communication becomes insecure

### Applications

- File encryption
- Disk encryption
- VPNs
- Secure communication
- Banking systems
- Wireless security

## Confusion and Diffusion

- Confusion and Diffusion are two fundamental principles of modern cryptography used to design strong encryption algorithms that resist cryptanalysis and attacks.
- The main goal is to make the relationship between: Plaintext, Ciphertext, Key as complex and unpredictable as possible.
- Modern encryption algorithms such as AES and DES use both confusion and diffusion together.

### Confusion

- Confusion is a cryptographic technique that makes the relationship between Ciphertext and Encryption key as complex and hidden as possible.
- The objective of confusion is to make it extremely difficult for an attacker to determine the encryption key even if they know the ciphertext.

### Objective of Confusion

- Hide key patterns
- Increase complexity of encryption
- Prevent attackers from guessing the key
- Make ciphertext appear random

### How Confusion is Achieved

Confusion is mainly achieved using:

1. Substitution operations
2. Non-linear transformations
3. S-boxes (Substitution boxes)

### Example of Confusion

Suppose plaintext is: HELLO

After applying substitutions and key transformations: XQTPZ

An attacker cannot easily determine:

- Which key was used
- Which substitutions were applied

### Characteristics of Confusion

- Makes key relationship complex
- Uses substitution techniques
- Produces unpredictable ciphertext
- Increases encryption security

### Advantages of Confusion

- Protects encryption keys
- Makes brute-force analysis harder
- Prevents statistical attacks
- Improves security strength

### Weaknesses Without Confusion

Without confusion:

- Key patterns become visible
- Cipher becomes predictable
- Attacks become easier

## Diffusion

- Diffusion is a cryptographic technique that spreads the influence of one plaintext character over many ciphertext characters. 1 bit change in plaintext significantly affects Cipher text
- The goal is to hide statistical patterns present in the plaintext.

### Objective of Diffusion

- Remove plaintext patterns
- Spread changes across ciphertext
- Prevent frequency analysis
- Increase randomness

### How Diffusion is Achieved

Diffusion is mainly achieved using:

1. Permutation
2. Transposition
3. Mixing operations

### Example of Diffusion

Suppose plaintext is: HELLO

If one letter changes: HELLO → CELLO

A good diffusion mechanism causes many ciphertext characters to change.

Example:

HELLO → QWERT

CELLO → PLMKO

Even a small plaintext change produces a large ciphertext change.

**Avalanche Effect:** Diffusion creates the Avalanche Effect. A small change in plaintext or key causes a large change in ciphertext.

**Example:** Changing one bit in plaintext may change: 50% or more ciphertext bits. This makes cryptanalysis extremely difficult.

### Characteristics of Diffusion

- Spreads plaintext influence
- Hides statistical properties
- Uses permutation/transposition
- Produces avalanche effect

### Advantages of Diffusion

- Prevents frequency analysis
- Increases randomness
- Improves ciphertext complexity
- Enhances security

## Weaknesses Without Diffusion

Without diffusion:

- Plaintext patterns remain visible

- Frequency analysis becomes possible
- Cipher becomes weak

## Difference Between Confusion and Diffusion

| Feature           | Confusion                                    | Diffusion                                    |
|-------------------|----------------------------------------------|----------------------------------------------|
| Purpose           | Hide relationship between key and ciphertext | Spread plaintext influence across ciphertext |
| Achieved By       | Substitution                                 | Permutation / Transposition                  |
| Focus             | Key complexity                               | Plaintext pattern hiding                     |
| Main Goal         | Make key difficult to find                   | Remove statistical patterns                  |
| Example Technique | S-box                                        | P-box                                        |

## Importance of Confusion and Diffusion

Together they:

- Strengthen encryption
- Prevent cryptanalysis
- Hide patterns
- Increase randomness
- Improve modern cipher security

Both principles are essential for designing secure block ciphers.

## Stream Cipher vs. Block Cipher

- Modern symmetric cryptography is split into two operational designs for handling data: **Stream Ciphers** and **Block Ciphers**. While stream ciphers encrypt data bit-by-bit, block ciphers encrypt fixed-size groups of data.
- To make block ciphers highly secure and efficient, cryptographers frequently rely on an architectural framework known as the **Feistel Cipher Structure**.

## Stream Ciphers

A stream cipher encrypts digital data continuously, **one bit or one byte at a time**.

- **How it works:** It uses a secret key to generate a continuous, pseudo-random stream of bits called a **keystream**. This keystream is combined with the plaintext bits, typically using a simple bitwise **XOR** operation.
- **Key Characteristics:**
  - Incredibly fast and requires minimal memory or computing power.
  - Low propagation error (an error in one ciphertext bit usually only corrupts that single bit during decryption).
  - Ideal for real-time, continuous data streams where buffering isn't possible (e.g., live telecommunications, streaming audio/video, or network protocols like RC4 or ChaCha20).

## Block Ciphers

A block cipher breaks down the plaintext into **fixed-size blocks** (typically 64, 128, or 256 bits) and encrypts the entire block simultaneously.

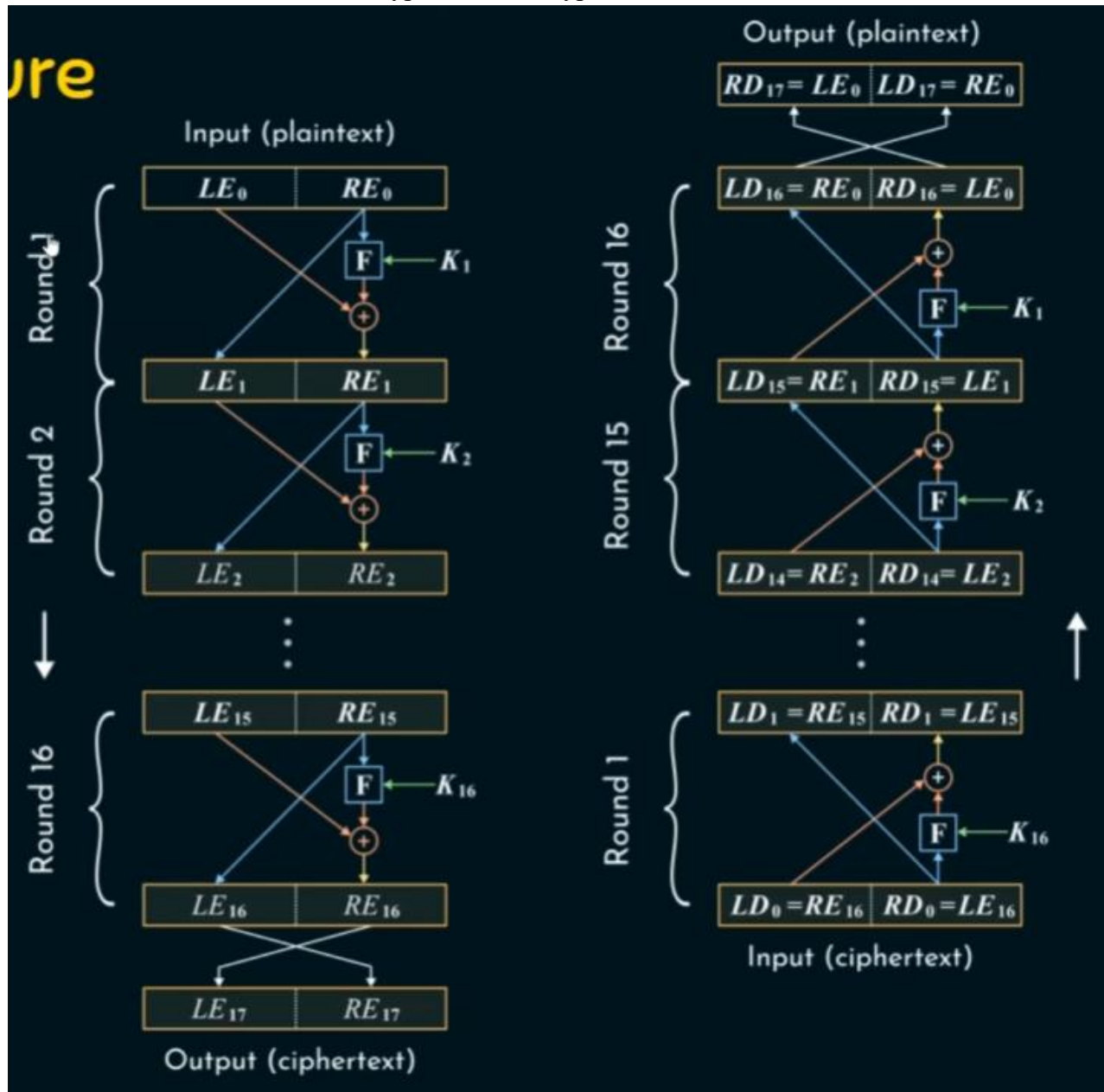
- **How it works:** If a message is smaller than the block size, it uses **padding** to fill the remaining space. If it's larger, it splits the data into chunks and processes them using a specific *Mode of Operation* (like CBC or GCM).
- **Key Characteristics:**
  - Slower than stream ciphers because data must be collected into blocks before processing.
  - Highly secure due to complex internal rounds of math mixing the bits together.
  - Ideal for file storage, database encryption, and secure web traffic (e.g., AES, DES).

| Feature            | Stream Cipher                                                                   | Block Cipher                                           |
|--------------------|---------------------------------------------------------------------------------|--------------------------------------------------------|
| Basic Idea         | Encrypts data bit by bit or byte by byte                                        | Encrypts data in fixed-size blocks                     |
| Speed              | Very fast                                                                       | Relatively slower                                      |
| Complexity         | Simple design                                                                   | More complex design                                    |
| Key Usage          | Uses a key stream generated from secret key                                     | Uses same key for each block (with rounds)             |
| Principal Used     | Confusion                                                                       | Both Confusion and Diffusion                           |
| Encryption Modes   | CFB (Cipher Feedback), OFB (Output Feedback)                                    | ECB (Electronic Codebook), CBC (Cipher Block Chaining) |
| Decryption Method  | XOR operation (same as encryption in most cases)                                | Reverse of encryption process using same key           |
| Memory Requirement | Low                                                                             | Higher                                                 |
| Error Propagation  | Affects only one bit/byte                                                       | Affects entire block                                   |
| Padding Required   | No padding needed                                                               | Padding required if data is not multiple of block size |
| Security Level     | Moderate (depends on key stream quality)<br>Very dangerous if key stream reused | High security                                          |
| Suitable For       | Real-time data transmission                                                     | File encryption, databases                             |
| Latency            | Very low                                                                        | Higher due to block processing                         |
| Examples           | RC4, Vernam Cipher                                                              | AES, DES, Blowfish, 3DES                               |

# The Feistel Cipher Structure

Feistel Cipher Structure is a symmetric encryption design model used in many block ciphers. Many modern encryption algorithms are based on Feistel structure. It is a repeatable structural design framework. It serves as the foundation for classic ciphers like **DES (Data Encryption Standard)** and Blowfish.

- Plaintext block is divided into two equal halves
- Multiple rounds of processing are performed
- Same structure is used for encryption and decryption



The Feistel network splits a data block into two equal halves, Left (L) and Right (R), and processes them through multiple rounds.



## 1. Encryption Process (Left Side of Diagram)

The encryption takes a plaintext block, splits it, and moves downward from Round 1 to Round 16.

### Initial Split

The plaintext block is divided into two halves:

- $LE_0 \rightarrow$  Left Encryption initial state
- $RE_0 \rightarrow$  Right Encryption initial state

### General Round Execution ( $i = 1$ to $16$ )

For any round  $i$ , the new states are computed as:

#### Left Half Update

The new left half is a direct copy of the previous right half:

$$LE_i = RE_{i-1}$$

#### Right Half Update

The previous right half  $RE_{i-1}$  and round subkey  $K_i$  are passed into function  $F$ .  
The output is XORed with the previous left half:

$$RE_i = LE_{i-1} \oplus F(RE_{i-1}, K_i)$$

### Final Swap (After Round 16)

After the 16th round, a final swap is performed to form ciphertext:

$$LE_{17} = RE_{16}$$

$$RE_{17} = LE_{16}$$

## 2. Decryption Process (Right Side of Diagram)

Decryption takes the ciphertext and moves upward from Round 1 to Round 16.

The same function  $F$  is used, but subkeys are applied in reverse order:

$$K_{16} \rightarrow K_1$$

### Initial Split (From Ciphertext)

Ciphertext is mapped as:

$$LD_0 = RE_{16}$$

$$RD_0 = LE_{16}$$

### General Round Execution ( $j = 1$ to 16)

The decryption process mirrors encryption because:

$$A \oplus B \oplus B = A$$

### Left Half Update

$$LD_j = RD_{j-1}$$

### Right Half Update

$$RD_j = LD_{j-1} \oplus F(RD_{j-1}, K_{17-j})$$

### 3. Mathematical Proof of Equivalence

To understand why decryption works, compare Decryption Round 1 with Encryption Round 16.

#### From Encryption Round 16

$$LE_{16} = RE_{15}$$

$$RE_{16} = LE_{15} \oplus F(RE_{15}, K_{16})$$

#### Decryption Round 1 Input

$$LD_0 = RE_{16}$$

$$RD_0 = LE_{16} = RE_{15}$$

#### Decryption Round 1

$$LD_1 = RD_0 = RE_{15}$$

$$RD_1 = LD_0 \oplus F(RD_0, K_{16})$$

Substitute values:

$$RD_1 = [LE_{15} \oplus F(RE_{15}, K_{16})] \oplus F(RE_{15}, K_{16})$$

Using XOR property:

$$A \oplus B \oplus B = A$$

So:

$$RD_1 = LE_{15}$$

#### Result After Round 1

$$(LD_1, RD_1) = (RE_{15}, LE_{15})$$

This matches the state before Encryption Round 16, proving that the Feistel structure reverses step by step.

## 1. Structural Elements: The Math & Mechanics

- a. **XOR ( $\oplus$ ):** The Exclusive OR (XOR) operation is the mathematical backbone of the Feistel structure. It has key properties:

$$A \oplus B \oplus B = A$$

$$A \oplus 0 = A$$

### Design Role:

- XOR combines the output of the round function  $F$  with one half of the data block.
- It ensures that no information is permanently lost.
- This property makes the cipher reversible during decryption.

- b. **Swap:** At the end of every round, the left and right halves are exchanged:

$$L_i = R_{i-1}$$

### Design Role:

- Ensures both halves are processed equally.
- Prevents one half from remaining unchanged.

- Enables full diffusion across rounds.

### Without swapping:

- One half would remain unused
- Security would be significantly weaker

## 2. Core Tuning Parameters

- a. **Block Size:** Defines the size of data processed in one operation. Data is split into two equal halves. **Typical values:**

- 64 bits (e.g., legacy systems like DES)
- 128 bits (modern systems)

### Design Impact:

- Small block size  $\rightarrow$  repetition patterns  $\rightarrow$  birthday/statistical attacks
- Large block size  $\rightarrow$  slower performance
- Balanced size ensures security + efficiency

- b. **Key Size:** Length of the master secret key. **Typical values:** 128, 192, 256 bits (modern standards)

### Design Impact:

- Determines resistance to brute-force attacks
- Larger key  $\rightarrow$  exponentially harder to break
- Directly controls security strength

- c. **Number of Rounds:** Feistel cipher is iterative. Each round applies the same structure with different subkeys. **Typical range:** 16 to 32 rounds

### Design Impact:

- Few rounds  $\rightarrow$  weak security
- More rounds  $\rightarrow$  higher confusion and diffusion
- Sufficient rounds make ciphertext appear random

### 3. Algorithmic Functions

- a. **Round Function (F):** The round function  $F$  is the core security component. It takes one half of the data block and a round subkey to create a complex, pseudo-random bit pattern.

**Internal operations:**

- Substitution (S-boxes) → Confusion
- Permutation (P-boxes) → Diffusion

**Design Role:**

- Introduces non-linearity
- Prevents mathematical prediction of output
- Strengthens resistance to cryptanalysis

- b. **Subkey Generation (Key Schedule):** Master This algorithm takes the master user key and slices/shifts/permutates it to generate a unique, smaller subkey ( $K_i$ ) for each specific round.

$$K_1, K_2, \dots, K_n$$

**Process:**

- Permutations
- Shifting
- Compression

**Design Role:**

- Ensures each round uses a different key
- Prevents simple key recovery
- Protects against partial key leakage

### 4. Performance & Ease of Analysis

- a. **Fast Encryption / Decryption Efficiency Features:** Uses simple operations:

- XOR
- Bit shifts
- Table lookups (S-boxes)

**Hardware Advantage:**

- Same structure for encryption and decryption
- Only subkeys are reversed
- Saves hardware and memory resources

**Design Benefit:**

- High speed in software and hardware implementations
- Suitable for real-time systems

- b. **Ease of Analysis:** Feistel structure is easy to analyze mathematically because:

- Clear separation of halves
- Well-defined round structure
- Predictable transformations per round

**Security Testing:**

- Differential cryptanalysis
- Linear cryptanalysis

**Design Benefit:**

- Cryptographers can determine required number of rounds
- Helps prove strength of cipher before deployment

# MODULE 3.2: SYMMETRIC KEY ALGORITHM

## Contents

|                                                     |    |
|-----------------------------------------------------|----|
| Data Encryption Standard (DES).....                 | 1  |
| DES Encryption Process.....                         | 2  |
| Decryption Process.....                             | 4  |
| Key Scheduling.....                                 | 4  |
| Advanced Encryption Standard (AES).....             | 5  |
| AES Encryption Process.....                         | 6  |
| International Data Encryption Algorithm (IDEA)..... | 8  |
| IDEA Encryption Process.....                        | 9  |
| RC5 (Rivest Cipher 5) .....                         | 10 |
| RC5 Encryption Process.....                         | 11 |

## Data Encryption Standard (DES)

The Data Encryption Standard (DES) is a symmetric key block cipher used for secure data encryption. It is based on the Feistel cipher structure, designed for efficient hardware and software implementation.

| Feature      | Description                                           |
|--------------|-------------------------------------------------------|
| Type         | Symmetric key block cipher                            |
| Structure    | Feistel network                                       |
| Developed By | IBM                                                   |
| Adopted By   | National Institute of Standards and Technology (NIST) |

It was once the most widely used encryption standard for protecting sensitive information. While DES is now considered insecure against modern brute-force attacks due to its small key size, its architectural design laid the groundwork for modern cryptography.

### Key Idea of DES

DES encrypts data by:

- Splitting 64-bit plaintext into two halves
- Applying 16 rounds of Feistel operations
- Using different subkeys in each round

The same structure is used for both encryption and decryption (with reversed keys).

| Feature                                      | Description |
|----------------------------------------------|-------------|
| Block Size (Both Input and Output size)      | 64 bits     |
| Main Key Size                                | 64 bits     |
| Sub Key Size (After excluding 8 bits parity) | 56 bits     |
| Round Key                                    | 48 bits     |
| Rounds                                       | 16 rounds   |

### DES Encryption Flow (Short Form)

1. Input 64-bit plaintext.
2. Apply Initial Permutation (IP).
3. Split into  $L_0$  and  $R_0$  (32 bits each).
4. Generate sixteen 48-bit round keys.
5. Expand  $R$  from 32 bits to 48 bits.
6. XOR with round key.
7. Apply S-Box substitution.
8. Apply P-Box permutation.
9. XOR with left half.
10. Swap halves.
11. Repeat Steps 5–10 for 16 rounds.
12. Perform final swap.
13. Apply Final Permutation  $IP^{-1}$ .
14. Obtain 64-bit ciphertext.

### Strengths of DES

- Fast in hardware implementation
- Strong confusion and diffusion

- Well-studied and standardized
- Uses Feistel structure (same encryption/decryption design)

### Weaknesses of DES

- Small key size (56-bit), so  $2^{56}$  possible key values → vulnerable to brute force
- Now considered insecure for modern systems
- Susceptible to exhaustive key search attacks

### Importance of DES

## DES Encryption Process

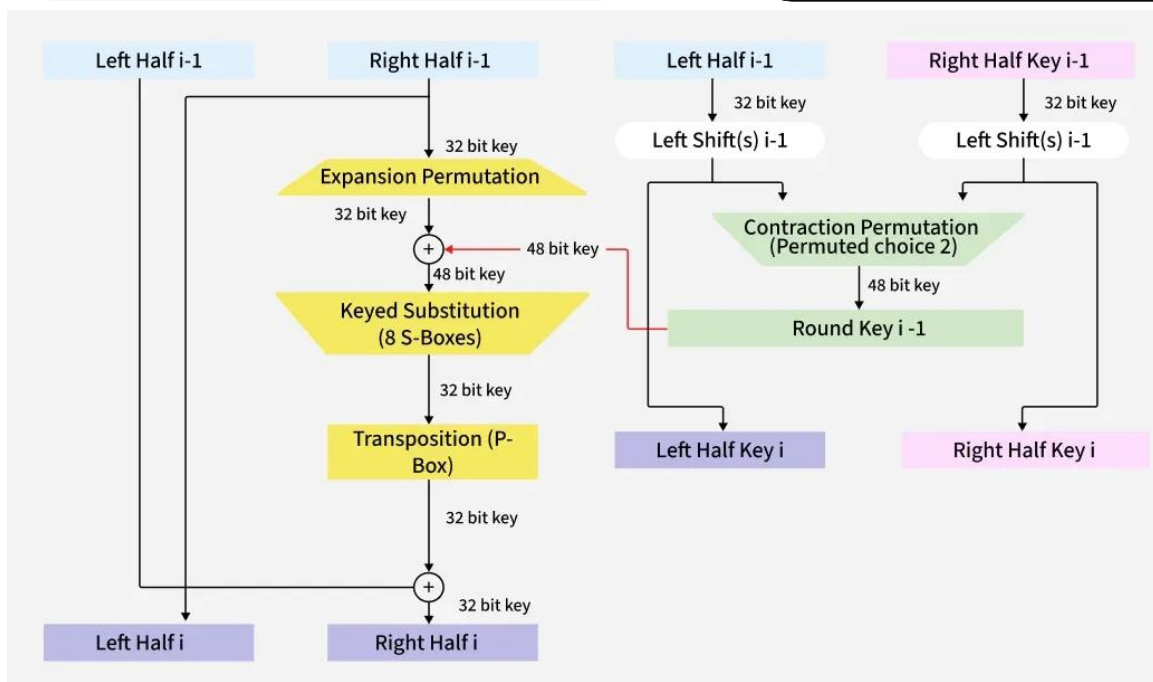
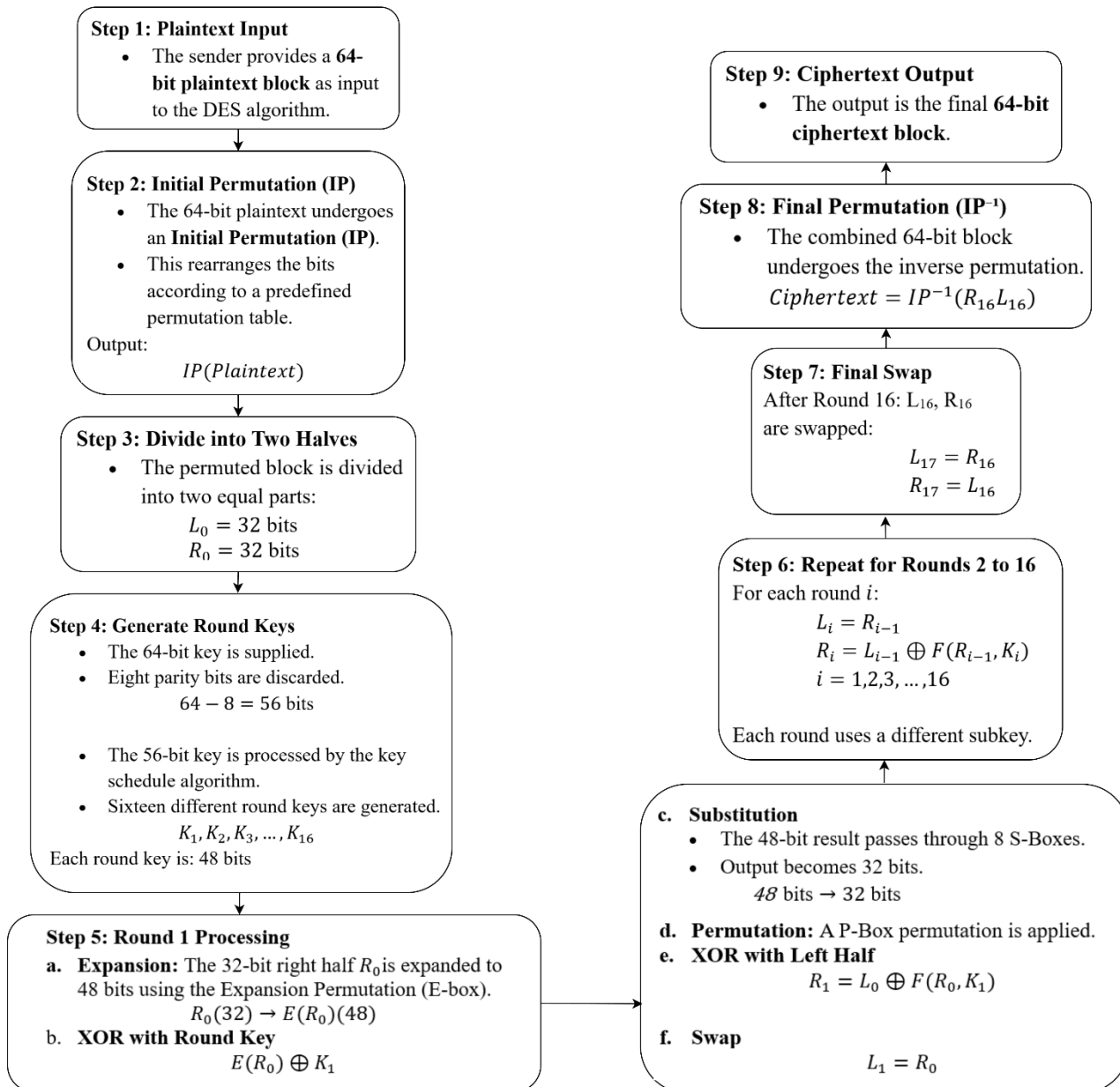


DES is historically important because:

- It was the first widely accepted encryption standard
- It introduced Feistel network in real-world cryptography
- It led to modern encryption systems like AES

### Real-Life Use (Historical)

- Banking systems
- Government communication
- ATM security (earlier systems)

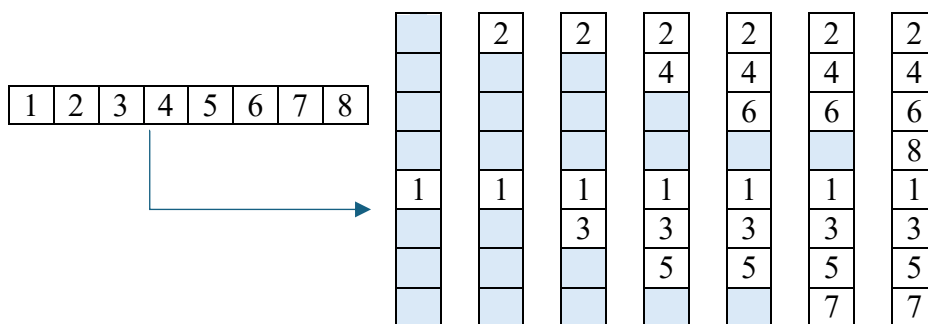


**Step 5 in details**



## Initial Permutation

|    |    |    |    |    |    |    |    |  |    |    |    |    |    |    |    |   |
|----|----|----|----|----|----|----|----|--|----|----|----|----|----|----|----|---|
| 1  | 2  | 3  | 4  | 5  | 6  | 7  | 8  |  | 58 | 50 | 42 | 34 | 26 | 18 | 10 | 2 |
| 9  | 10 | 11 | 12 | 13 | 14 | 15 | 16 |  | 60 | 52 | 44 | 36 | 28 | 20 | 12 | 4 |
| 17 | 18 | 19 | 20 | 21 | 22 | 23 | 24 |  | 62 | 54 | 46 | 38 | 30 | 22 | 14 | 6 |
| 25 | 26 | 27 | 28 | 29 | 30 | 31 | 32 |  | 64 | 56 | 48 | 40 | 32 | 24 | 16 | 8 |
| 33 | 34 | 35 | 36 | 37 | 38 | 39 | 40 |  | 57 | 49 | 41 | 33 | 25 | 17 | 9  | 1 |
| 41 | 42 | 43 | 44 | 45 | 46 | 47 | 48 |  | 59 | 51 | 43 | 35 | 27 | 19 | 11 | 3 |
| 49 | 50 | 51 | 52 | 53 | 54 | 55 | 56 |  | 61 | 53 | 45 | 37 | 29 | 21 | 13 | 5 |
| 57 | 58 | 59 | 60 | 61 | 62 | 63 | 64 |  | 63 | 55 | 47 | 39 | 31 | 23 | 15 | 7 |



**Inverse Initial Permutation** means inversed each mapping

IP says:  $58 \rightarrow 1$

then inverse says:  $1 \rightarrow 58$

## Decryption Process

- Same structure as encryption
- Only difference is subkeys are used in reverse order:  $K_1 \rightarrow K_{16}, K_2 \rightarrow K_{15}, \dots, K_{16} \rightarrow K_1$

## Key Scheduling

### Key Scheduling

#### 1. Permuted Choice 1 (PC-1):

- The original DES key is **64 bits** long.
- Every 8th bit is a **parity bit** and is discarded.
- Parity bit positions are:

$8, 16, 24, 32, 40, 48, 56, 64$

- After removing these 8 parity bits, the key size becomes:

$64 - 8 = 56 \text{ bits}$

- The 56-bit key is then permuted and divided into two halves:

$C_0 = 28 \text{ bits}, \quad D_0 = 28 \text{ bits}$

## 2. Left Circular Shift:

- The two 28-bit halves ( $C_i$  and  $D_i$ ) are shifted left circularly before each round.
- A circular shift means that the leftmost bit removed from the front is inserted back at the right end.
- The number of shifts depends on the round number.
- Rounds 1, 2, 9, and 16 use a 1-bit shift.
- All other rounds use a 2-bit shift.
- This process generates a different key arrangement for each round, improving security.

## 3. Permuted Choice 2 (PC-2):

- After the left circular shifts, the two halves are combined again to form a 56-bit key.
- PC-2 selects and permutes 48 bits from these 56 bits.
- The resulting 48-bit output forms the round key ( $K_i$ ) for that round.

56 bits  $\rightarrow$  48 bits

- One unique round key is generated for each of the 16 rounds:

$K_1, K_2, K_3, \dots, K_{16}$

- These round keys are used by the DES round function during encryption and decryption.

# Advanced Encryption Standard (AES)

AES is a **symmetric key block cipher** used worldwide for secure data encryption. It replaced DES due to its stronger security.

| Feature    | Description                                    |
|------------|------------------------------------------------|
| Type       | Symmetric key block cipher                     |
| Block Size | 128 bits                                       |
| Key Sizes  | 128, 192, 256 bits                             |
| Structure  | Substitution–Permutation Network (NOT Feistel) |
| Rounds     | 10, 12, 14 (depending on key size)             |

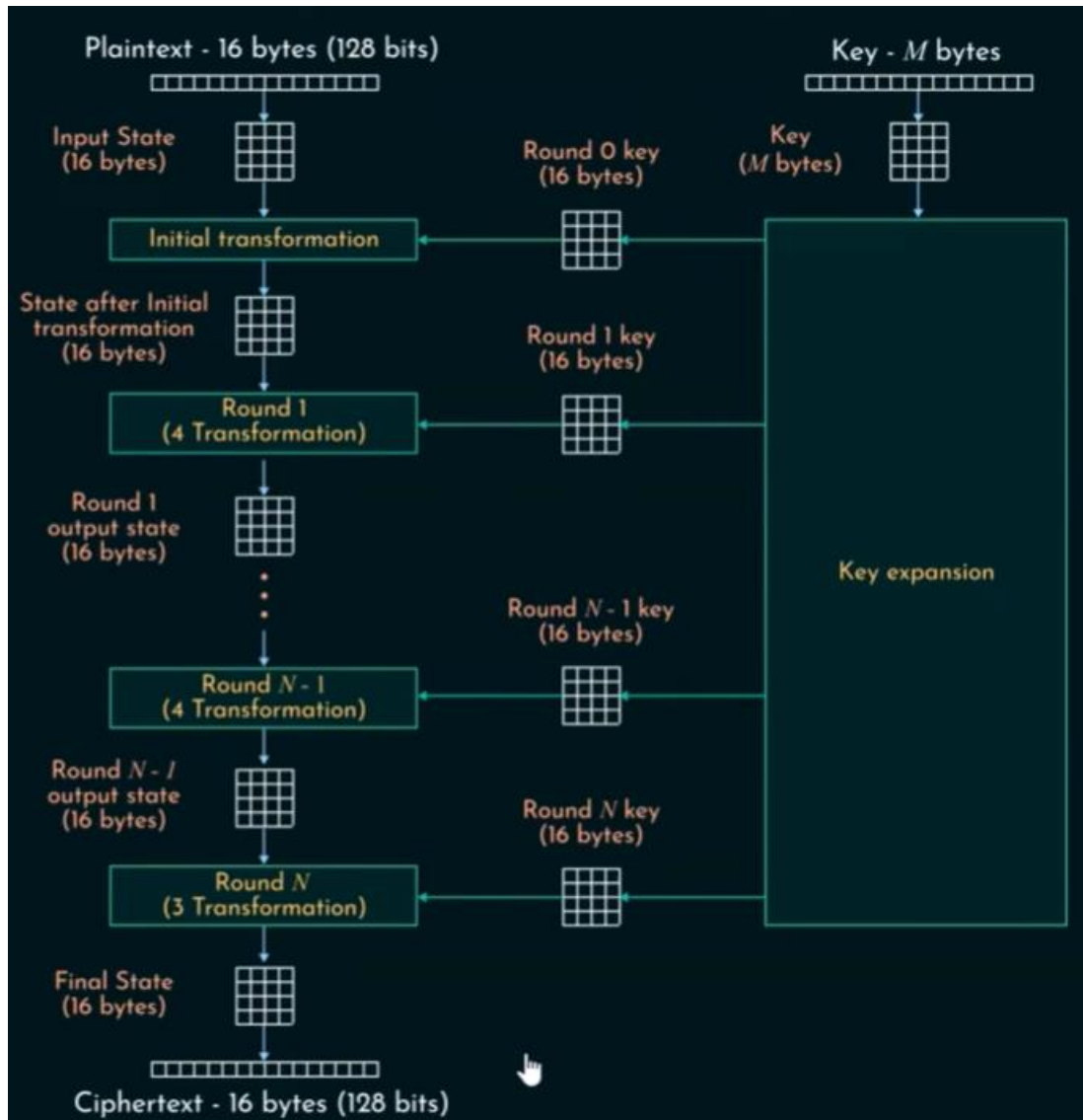
## AES Block Structure

- Input block = **128 bits**
- Represented as a **4 × 4 matrix (State matrix)**

|     |     |     |     |
|-----|-----|-----|-----|
| B0  | B1  | B2  | B3  |
| B4  | B5  | B6  | B7  |
| B8  | B9  | B10 | B11 |
| B12 | B13 | B14 | B15 |

| Key Size (M) | No of Rounds (N) | Round Key size    | Plain Text Size   |
|--------------|------------------|-------------------|-------------------|
| 128-bit      | 10 rounds        | 128-bit (16 byte) | 128-bit (16 byte) |
| 192-bit      | 12 rounds        | 128-bit (16 byte) | 128-bit (16 byte) |
| 256-bit      | 14 rounds        | 128-bit (16 byte) | 128-bit (16 byte) |

# AES Encryption Process



## 1) Plaintext Input

- AES takes a **128-bit plaintext block (16 bytes)** as input.
- The plaintext is arranged into a **4 × 4 State Matrix**.

## 2) Key Expansion

- The secret key (128, 192, or 256 bits) is expanded into multiple **Round Keys**.
- One round key is used in each round of encryption.

## 3) Initial Transformation (Round 0)

- The plaintext state is XORed with the initial round key.  
 $State = State \oplus RoundKey_0$
- This step is called **AddRoundKey**.

## 4) Round 1 to Round (N-1)

Each round consists of the following four transformations:

### a) SubBytes

- Each byte in the State Matrix is replaced using the AES S-Box.
- Provides **confusion**.

### b) ShiftRows

- Rows of the State Matrix are shifted left.
- Provides **diffusion**.

| Row   | Shift |
|-------|-------|
| Row 0 | 0     |
| Row 1 | 1     |
| Row 2 | 2     |
| Row 3 | 3     |

### c) MixColumns

- Each column is transformed using matrix multiplication in  $GF(2^8)$ .
- Further increases diffusion.

### d) AddRoundKey

- The current state is XORed with the round key.  
 $State = State \oplus RoundKey_i$

## 6) Ciphertext Output

- The final State Matrix is converted back into a **128-bit ciphertext block**.  
 $Ciphertext = Final\ State$

## 5) Final Round (Round N)

The final round consists of only **three transformations**:

### a) SubBytes

### b) ShiftRows

### c) AddRoundKey

- **MixColumns** is omitted in the final round.

### AES Encryption Flow (Short Form)

1. Input 128-bit plaintext.
2. Arrange plaintext into State Matrix.
3. Perform Key Expansion.
4. Apply initial AddRoundKey.
5. Perform SubBytes.
6. Perform ShiftRows.
7. Perform MixColumns.
8. Perform AddRoundKey.
9. Repeat Steps 5–8 for all intermediate rounds.
10. In the final round perform:
  - SubBytes
  - ShiftRows
  - AddRoundKey
11. Generate 128-bit ciphertext.

### Advantages of AES

- DES has fixed no of 16 encryption rounds but AES has N rounds.
- Very strong security
- Large key sizes (128/192/256 bits)
- Resistant to brute-force & Statistical attacks

- Efficient in hardware and software
- Cheap hardware
- Widely adopted globally

### Disadvantages

- More complex than DES
- Requires more computational resources

| Feature                  | DES (Data Encryption Standard)                           | AES (Advanced Encryption Standard)                 |
|--------------------------|----------------------------------------------------------|----------------------------------------------------|
| Cipher Type              | Symmetric Block Cipher                                   | Symmetric Block Cipher                             |
| Structure                | Feistel Network                                          | Substitution-Permutation Network (SPN)             |
| Block Size               | 64 bits                                                  | 128 bits                                           |
| Key Size                 | 56 bits (effective)                                      | 128, 192, or 256 bits                              |
| Number of Rounds         | 16                                                       | 10, 12, or 14                                      |
| Round Key Size           | 48 bits                                                  | 128 bits                                           |
| Security                 | Less secure; vulnerable to brute-force attacks           | Highly secure and widely used                      |
| Speed                    | Slower                                                   | Faster                                             |
| Confusion & Diffusion    | Achieved using Feistel rounds, S-boxes, and permutations | Achieved using SubBytes, ShiftRows, and MixColumns |
| Encryption & Decryption  | Same structure with reverse round keys                   | Different inverse operations used for decryption   |
| Key Scheduling           | Generates 16 round keys                                  | Generates round keys through Key Expansion         |
| Resistance to Attacks    | Vulnerable due to small key size                         | Strong resistance to known attacks                 |
| Computational Efficiency | Lower                                                    | Higher                                             |
| Current Usage            | Mostly obsolete                                          | Widely used in modern applications                 |
| Applications             | Legacy systems                                           | VPNs, Wi-Fi, SSL/TLS, Banking, Cloud Security      |

# International Data Encryption Algorithm (IDEA)

The **International Data Encryption Algorithm (IDEA)** is a symmetric-key block cipher designed as a replacement for DES and provides stronger security through the use of multiple mathematical operations.

| Feature           | Description                            |
|-------------------|----------------------------------------|
| Cipher Type       | Symmetric Block Cipher                 |
| Block Size        | 64 bits                                |
| Key Size          | 128 bits                               |
| Number of Rounds  | 8 rounds + 1 Output Transformation     |
| Subkeys Generated | 52 subkeys                             |
| Subkey Size       | 16 bits each                           |
| Structure         | Substitution-Permutation Network (SPN) |
| Year Introduced   | 1991                                   |

## Basic Principle

IDEA achieves security by combining three different operations:

1. Bitwise XOR ( $\oplus$ )
2. Addition modulo  $2^{16}$
3. Multiplication modulo  $(2^{16}+1)$

These operations belong to different algebraic groups, making cryptanalysis extremely difficult.

## Block Division

- Plaintext block = 64 bits
- Divided into four 16-bit sub-blocks:  
 $X_1, X_2, X_3, X_4$
- Each sub-block: 16 bits

## Advantages of IDEA

1. Strong security.
2. Resistant to differential and linear cryptanalysis.
3. Uses a large 128-bit key.
4. No practical attacks on the full IDEA algorithm.
5. Combines three different mathematical operations for enhanced confusion and diffusion.

## Key Scheduling

- User provides a **128-bit key**.
- The key schedule generates: 52 subkey
- Each subkey is: 16 bits

## Distribution of Subkeys

- Rounds 1–8 require 6 subkeys each  $8 \times 6 = 48$
- Output transformation requires 4 subkeys  $48 + 4 = 52$
- Thus, total subkeys: 52

## Disadvantages of IDEA

1. More computationally intensive than some modern ciphers.
2. Complex key scheduling.
3. Slower than AES in software implementations.
4. Largely replaced by AES in modern applications.

# IDEA Encryption Process

## Step 1: Input Plaintext

- Take a 64-bit plaintext block.
- Divide into four 16-bit blocks:  $X_1, X_2, X_3, X_4$

## Step 2: Perform 8 Rounds

Each round uses six subkeys:  $K_1, K_2, K_3, K_4, K_5, K_6$

### Round Operations

- Multiplication:**  $X_1 = X_1 \times K_1 \pmod{2^{16} + 1}$
- Addition:**  $X_2 = X_2 + K_2 \pmod{2^{16}}$
- Addition:**  $X_3 = X_3 + K_3 \pmod{2^{16}}$
- Multiplication:**  $X_4 = X_4 \times K_4 \pmod{2^{16} + 1}$
- XOR Operations:** Intermediate values are generated using XOR operations.
- Additional Multiplication and Addition** Subkeys  $K_5$  and  $K_6$  are used.
- Swap:**  $X_2 \leftrightarrow X_3$ . The second and third blocks are swapped after every round except the final round.

## Step 4: Generate Ciphertext

- The resulting four 16-bit blocks are combined to form: 64-bit Ciphertext

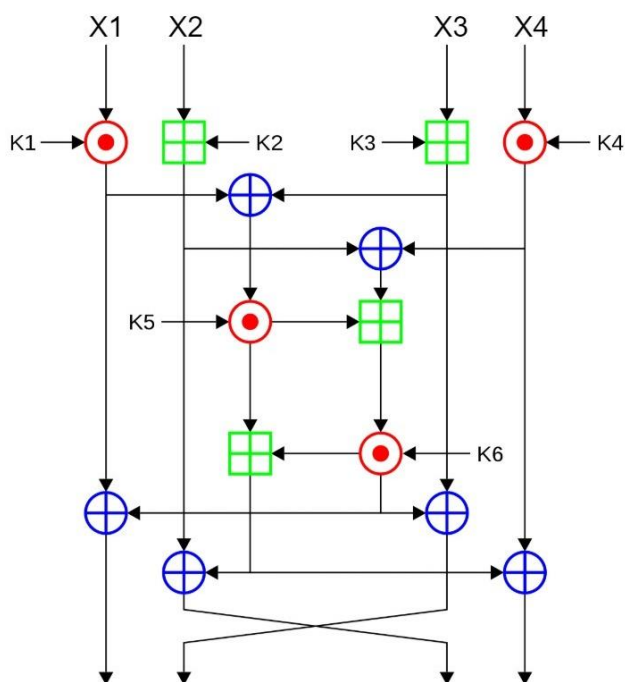
## Step 3: Output Transformation

After Round 8, a final transformation is performed using four remaining subkeys.

Operations:

- Multiplication
- Addition
- Addition
- Multiplication

using subkeys:  $K_{49}, K_{50}, K_{51}, K_{52}$



Where,



= Modular Addition



= Modular Multiplication



= Bitwise XOR

1. Input 64-bit plaintext.
2. Divide plaintext into four 16-bit blocks.
3. Generate 52 subkeys from the 128-bit key.
4. Perform 8 rounds of encryption using multiplication, addition, and XOR operations.
5. Swap middle two blocks after each round.
6. Perform final output transformation using four remaining subkeys.
7. Combine the four 16-bit blocks.
8. Obtain the 64-bit ciphertext.

### IDEA Round Structure

For each round:

1. Multiply  $X_1$  with  $K_1$
2. Add  $X_2$  with  $K_2$
3. Add  $X_3$  with  $K_3$
4. Multiply  $X_4$  with  $K_4$
5. XOR intermediate values
6. Multiply using  $K_5$
7. Add using  $K_6$
8. XOR operations
9. Swap  $X_2$  and  $X_3$

### Decryption in IDEA

- Uses the same algorithm structure.
- Requires specially generated inverse subkeys.
- Operations are reversed using:
  - Multiplicative inverse modulo  $(2^{16}+1)$
  - Additive inverse modulo  $2^{16}$

### Important Formulae

- Addition:  $A + B \pmod{2^{16}}$
- Multiplication:  $A \times B \pmod{(2^{16} + 1)}$
- XOR:  $A \oplus B$

## RC5 (Rivest Cipher 5)

RC5 is a **symmetric-key block cipher** designed by **Ron Rivest** in 1994. It is known for its simplicity, flexibility, and parameterized design.

### Features of RC5

| Feature          | Description                      |
|------------------|----------------------------------|
| Cipher Type      | Symmetric Block Cipher           |
| Structure        | Feistel-like Network             |
| Block Size       | Variable (32, 64, 128 bits)      |
| Key Size         | Variable (0–2040 bits)           |
| Number of Rounds | Variable (0–255 rounds)          |
| Operations Used  | XOR, Addition, Circular Rotation |

### RC5 Parameters

RC5 is represented as: RC5 – w/r/b . RC5-32/12/16, you say: "RC5 with 32-bit words, 12 rounds, and a 16-byte key.

- w= Word size (16, 32, or 64 bits)
- r= Number of rounds
- b= Key length in bytes



## RC5 Block Structure

A plaintext block consists of two words:  $A, B$

Each word has  $w$  bits.

For RC5-32:

$$A = 32 \text{ bits}$$

$$B = 32 \text{ bits}$$

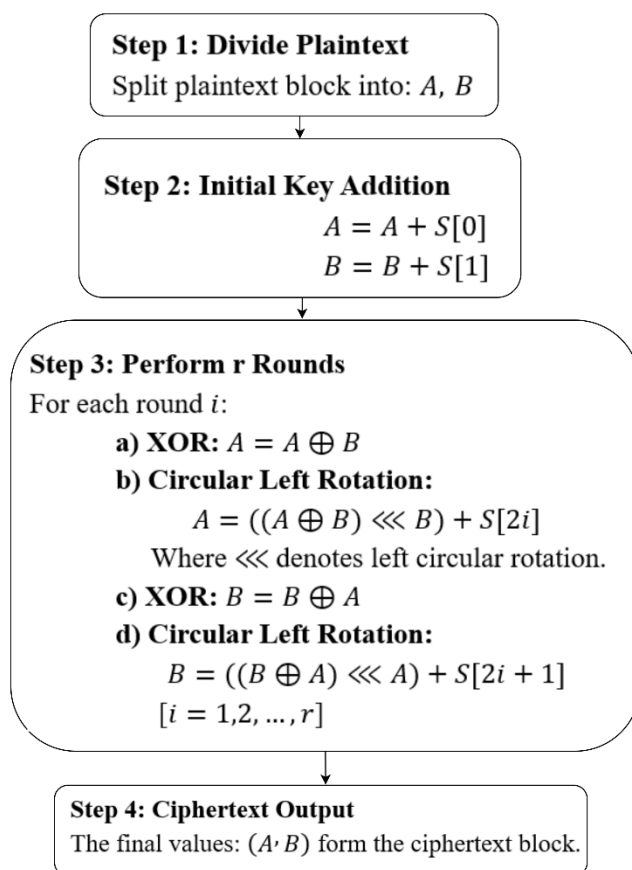
Therefore, *Block Size* = 64 bits

## Key Expansion

- User provides a secret key.
- The key expansion algorithm generates:  $S[0], S[1], S[2], \dots, S[2r + 1]$

For  $r$  rounds:  $2r + 2$  subkeys are generated. **Example:** For 12 rounds:  $2(12) + 2 = 26$  subkeys.

## RC5 Encryption Process



## RC5 Encryption Flow

1. Input plaintext.
2. Split into two words  $A$  and  $B$ .
3. Add first two subkeys.
4. XOR  $A$  with  $B$ .
5. Rotate left.
6. Add round key.
7. XOR  $B$  with  $A$ .
8. Rotate left.
9. Add round key.
10. Repeat for all rounds.
11. Obtain ciphertext.

## RC5 Decryption

- Decryption performs the inverse operations.
- Round keys are used in reverse order.
- Rotations are reversed using right circular shifts.

## Operations Used in RC5

- 1) **XOR:**  $A \oplus B$  Provides confusion.
- 2) **Modular Addition:**  $A + B \pmod{2^w}$  Introduces non-linearity.
- 3) **Circular Rotation** Left Rotation:  $A \lll n$ . Example:  $10110001 \rightarrow 11000110$ . Provides diffusion.

## Advantages of RC5

1. Simple design.
2. Fast implementation.
3. Variable block size.
4. Variable key size.



5. Variable number of rounds.
6. Suitable for hardware and software implementations.

1. Patented algorithm (historically).
2. Less commonly used today compared to AES.
3. Security depends on chosen parameters.

### Disadvantages of RC5

### RC5 vs DES

| Feature     | RC5                     | DES                |
|-------------|-------------------------|--------------------|
| Block Size  | Variable                | 64 bits            |
| Key Size    | Variable                | 56 bits            |
| Rounds      | Variable                | 16                 |
| Operations  | XOR, Addition, Rotation | Feistel Operations |
| Flexibility | High                    | Low                |
| Security    | Stronger                | Weaker             |

# MODULE 4: ASYMMETRIC KEY ALGORITHM & RSA

## Contents

|                                                          |   |
|----------------------------------------------------------|---|
| Asymmetric Key Cryptography .....                        | 1 |
| RSA .....                                                | 3 |
| Symmetric and Asymmetric Key Cryptography Together ..... | 5 |
| Digital Signature .....                                  | 6 |
| Message Digest .....                                     | 7 |
| Hash Function .....                                      | 8 |

## Asymmetric Key Cryptography

### Limitations of Symmetric Key Cryptography

1. **Key Distribution Problem:** The secret key must be shared securely between sender and receiver before communication.
2. **Scalability Issue:** The number of required keys increases rapidly as the number of users grows.
3. **Difficult Key Management:** Generating, distributing, storing, and updating keys becomes complex.
4. **Lack of Non-Repudiation:** Since both parties use the same key, the sender cannot be uniquely identified.
5. **Limited Authentication:** Symmetric encryption does not effectively verify user identity.
6. **Single Key Dependency:** The entire communication relies on one shared secret key.
7. **Key Compromise Risk:** If the secret key is exposed, all encrypted data can be accessed.
8. **Secure Storage Requirement:** Keys must be protected from unauthorized access and theft.
9. **High Administrative Overhead:** Managing numerous keys requires significant effort and resources.
10. **Not Suitable for Large Networks:** Key management becomes difficult in organizations with many users.
11. **Risk to Previous Communications:** A compromised key can expose previously encrypted messages.
12. **Dependence on Secure Channels:** A trusted method is required for exchanging secret keys securely.

### Asymmetric Key Cryptography

Asymmetric Key Cryptography, also known as **Public Key Cryptography**, is a cryptographic technique that uses **two different but mathematically related keys** for encryption and decryption.

- One key is called the **Public Key** and can be shared openly.
- The other key is called the **Private Key** and is kept secret by the owner.

This method eliminates the need to share a secret key before communication. **Popular Public Key Algorithms:** RSA, Diffie-Hellman

### Working Principle

1. The receiver generates a public key and a private key.
2. The public key is shared with everyone.
3. The sender encrypts the message using the receiver's public key.
4. The encrypted message is transmitted over the network.
5. The receiver decrypts the message using their private key.
6. Only the corresponding private key can decrypt data encrypted by the public key.

## Public Key and Private Key

1. **Public Key:** A public key is the key that can be freely distributed to anyone.
  - Shared openly.
  - Used for encryption.
  - Used for signature verification.
  - Does not need to be kept secret.
2. **Private Key:** A private key is the key that must remain confidential.
  - Known only to the owner.
  - Used for decryption.

- Used for digital signature creation.
- Must be protected from unauthorized access.

## Relationship Between Keys

- Public and private keys are mathematically related.
- Knowing the public key does not reveal the private key.
- Security depends on keeping the private key secret.

## Need for Public Key Cryptography

1. Secure key distribution was difficult.
2. Managing a large number of secret keys was complex.
3. Authentication mechanisms were limited.
4. Non-repudiation could not be achieved.
5. Communication over open networks required stronger security mechanisms.

## Advantages

1. **Secure Key Sharing:** Public keys can be shared openly.
2. **Authentication:** Verifies user identity.
3. **Digital Signatures:** Supports electronic signatures.
4. **Non-Repudiation:** Sender cannot deny a message.
5. **Better Scalability:** Fewer keys are required.
6. **No Secret Exchange:** No shared key is needed beforehand.
7. **Internet Friendly:** Suitable for public networks.
8. **High Security:** Private key remains secret.
9. **Secure Key Exchange:** Safely exchanges session keys.
10. **Wide Usage:** Used in modern security systems.
6. **Private Key Risk:** Security depends on key secrecy.
7. **Certificate Dependency:** Often requires certificates.
8. **More Storage:** Needs additional memory.
9. **Key Management Issues:** Poor management reduces security.
10. **Costly Operations:** Cryptographic calculations are expensive.

## Applications

1. **Secure Email:** Protects email communication.
2. **Digital Signatures:** Verifies documents and messages.
3. **HTTPS Security:** Secures web browsing.
4. **Online Banking:** Protects banking transactions.
5. **E-Commerce:** Secures online payments.
6. **VPN Security:** Enables secure remote access.
7. **Software Verification:** Authenticates software updates.
8. **PKI Systems:** Supports digital certificates.
9. **Cryptocurrency:** Used in blockchain systems.
10. **Key Exchange:** Distributes secret keys securely.

## Limitations

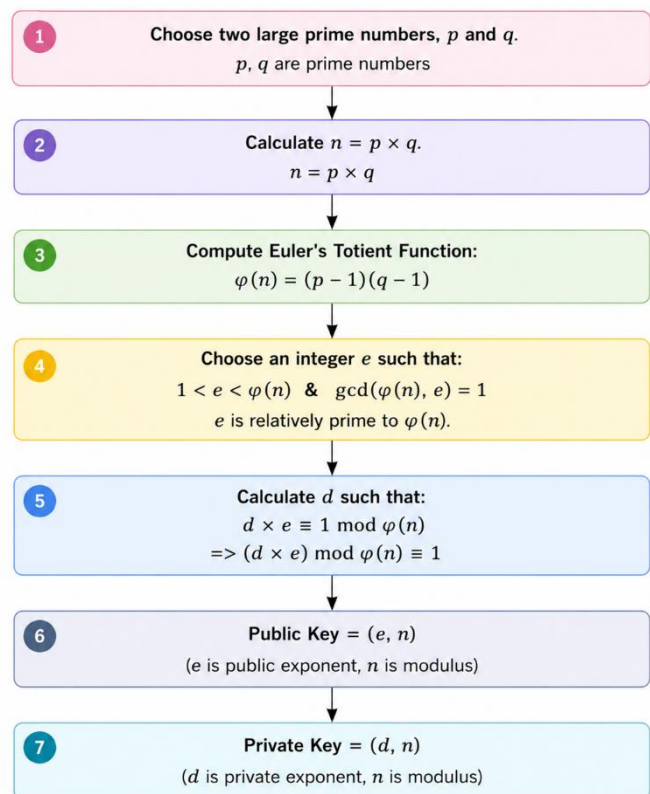
1. **Slower Speed:** Processing is relatively slow.
2. **High Computation:** Requires more resources.
3. **Large Keys:** Uses longer key lengths.
4. **Complex Design:** More difficult to implement.
5. **Lower Efficiency:** Not ideal for large data encryption.

# RSA

RSA (Rivest-Shamir-Adleman) is one of the most widely used asymmetric key cryptographic algorithms. RSA uses a pair of keys—a public key for encryption and a private key for decryption. It provides confidentiality, authentication, digital signatures, and secure key exchange.

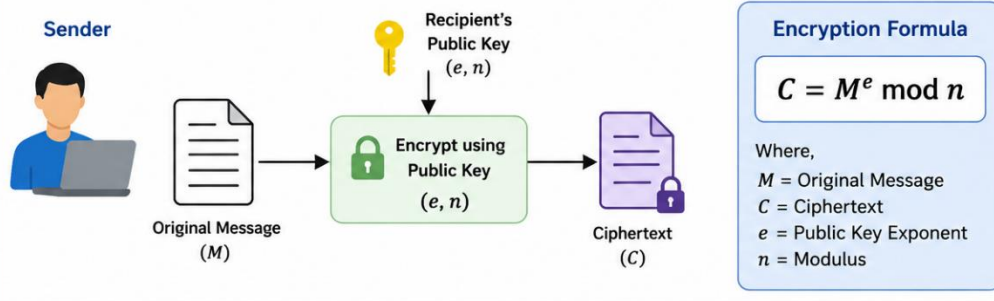
1. Uses public key and private key pair.
2. Based on asymmetric cryptography.
3. Provides confidentiality and authentication.
4. Supports digital signatures.
5. Ensures non-repudiation.
6. Public key can be shared openly.
7. Security depends on factorization of large prime numbers.
8. Widely used in Internet security protocols.
9. Supports secure key exchange.
10. Provides strong security with large key sizes.

## RSA Key Generation Process



## RSA ENCRYPTION PROCESS

RSA encryption is performed using the recipient's public key.



Where:

$C$  = Ciphertext

$M$  = Original Message

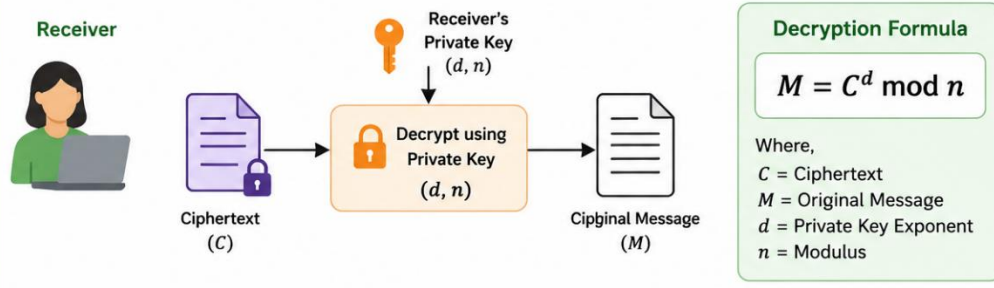
$d$  = Private Key Exponent

$n$  = Modulus

$e$  = Public Key Exponent

## RSA DECRYPTION PROCESS

RSA decryption is performed using the receiver's private key.



### Example

- ① Generate a private & public key using the prime nos  $p=3, q=11$ .  
Choose  $e=7$ .
- ② Encrypt the plaintext  $M=5$
- ③ Decrypt the ciphertext  $C$  (from ②)

### Answer

①  $n = pq = 33$

$$\phi(n) = (3-1)(11-1) = 20$$

Given,  $e = 7$  we check  $1 < e < \phi(n)$   
 $\Rightarrow 1 < 7 < 20$  (valid)

$$\gcd(7, 20) = 1 \text{ (valid)}$$

$$(de) \bmod \phi(n) \equiv 1 \Rightarrow (d \cdot 7) \bmod 20 \equiv 1$$

$$\boxed{d = 3}$$

$\therefore$  Public key:  $(e, n) = (7, 33)$

Private key:  $(d, n) = (3, 33)$

② Encryption formula:  $C = (M^e) \bmod n$   
 $(M=5, e=7, n=33)$   
 $= 5^7 \bmod 33$   
 $\boxed{C = 14}$

} Sender uses the Receiver's public key  $(7, 33)$

③ Decryption formula:  $M = (C^d) \bmod n$   
 $= 14^3 \bmod 33$   
 $\boxed{M = 5}$

} Receiver uses their private key  $(3, 33)$

### **Advantages of RSA**

1. Secure public key encryption.
2. Supports digital signatures.
3. Enables secure key exchange.
4. Provides authentication.
5. Ensures non-repudiation.
6. Public keys can be shared openly.
7. Widely accepted standard.

8. Suitable for Internet security.

### **Disadvantages of RSA**

1. Slower than symmetric algorithms.
2. Requires large key sizes.
3. Computationally expensive.
4. Not efficient for large data encryption.
5. Complex key management.
6. Higher memory usage.

7. Vulnerable if private key is exposed.
8. Performance decreases with larger keys.

### Applications of RSA

1. Secure web communication (HTTPS).
2. SSL/TLS protocols.
3. Digital signatures.
4. Secure email systems.

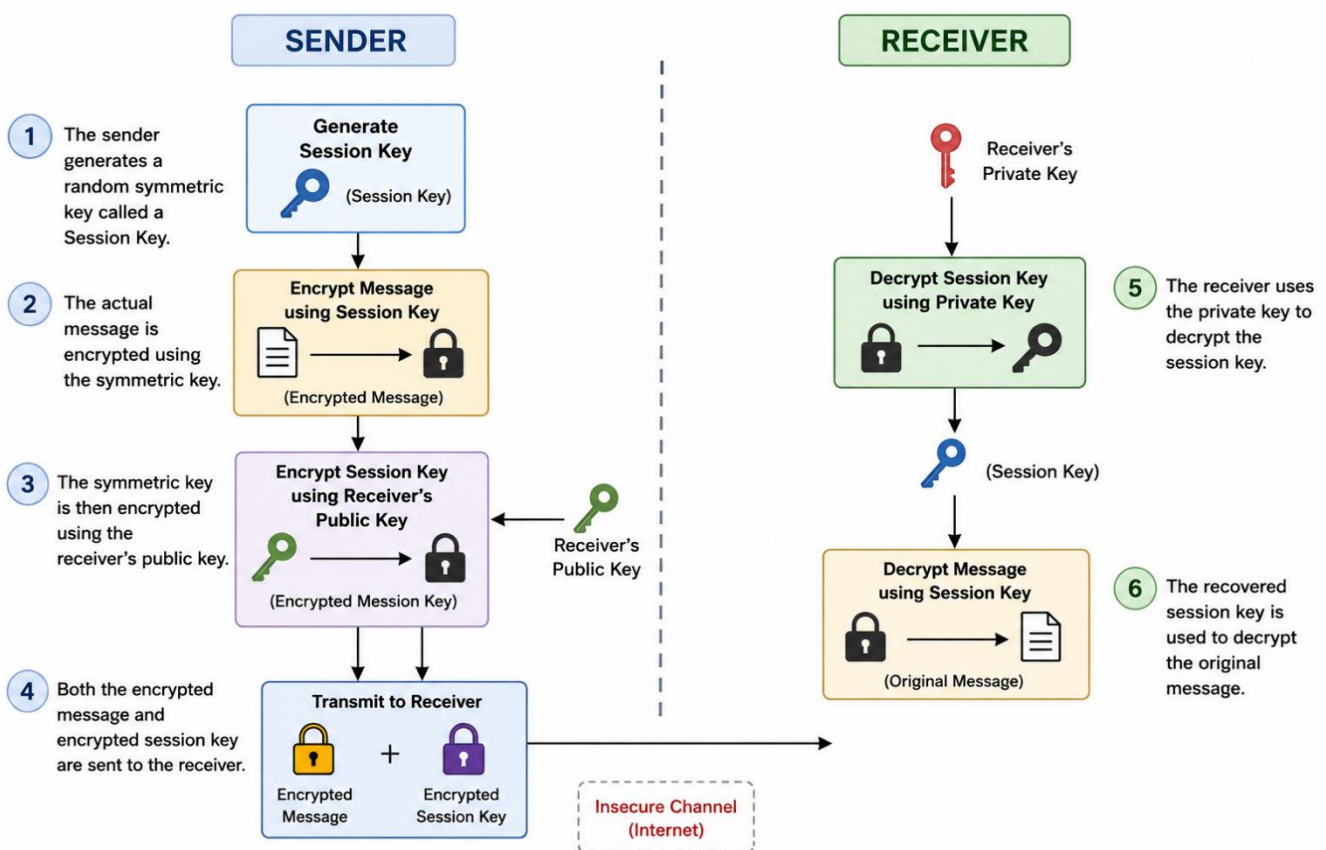
5. Online banking transactions.
6. E-commerce security.
7. Virtual Private Networks (VPNs).
8. Software authentication.
9. Public Key Infrastructure (PKI).
10. Secure exchange of cryptographic keys.

## Symmetric and Asymmetric Key Cryptography Together

Hybrid Cryptography is a security approach that combines Symmetric Key Cryptography and Asymmetric Key Cryptography to utilize the advantages of both methods. It uses asymmetric encryption for secure key exchange and symmetric encryption for fast data transmission.

### Need for Hybrid Cryptography

1. Symmetric encryption is fast but suffers from key distribution problems.
2. Asymmetric encryption solves key distribution issues but is computationally slower.
3. Hybrid cryptography combines the speed of symmetric encryption with the security of asymmetric encryption.
4. It provides secure communication over insecure networks.
5. It is widely used in modern Internet security systems.



**Session Key:** is a temporary symmetric key used for encrypting and decrypting data during a single communication session.

1. Generated randomly for each session.
2. Used only for a limited period.
3. Provides fast encryption and decryption.
4. Enhances security by reducing key reuse.
5. Discarded after the communication session ends.



### Importance of Session Key

1. Improves encryption speed.
2. Reduces computational overhead.
3. Enhances confidentiality of transmitted data.
4. Minimizes the impact of key compromise.
5. Enables secure communication in hybrid cryptography.

### Examples: SSL/TLS, PGP and S/MIME

**1) SSL/TLS:** SSL (Secure Sockets Layer) and TLS (Transport Layer Security) are protocols used to secure Internet communications. **Working**

1. Asymmetric encryption is used to authenticate the server and exchange keys.
2. A session key is established securely.
3. Symmetric encryption is used for data transfer.
4. Provides confidentiality, integrity, and authentication.

**2) PGP (Pretty Good Privacy):** PGP is used for securing emails and files. **Working**

1. A session key is generated.
2. The message is encrypted using the session key.
3. The session key is encrypted using the receiver's public key.
4. The receiver decrypts the session key using the private key and then decrypts the message.

**3) S/MIME (Secure/Multipurpose Internet Mail Extensions):** S/MIME is a standard for secure email communication. **Working**

1. Uses digital certificates for authentication.
2. Generates a session key for message encryption.
3. Encrypts the session key using public key cryptography.
4. Provides email encryption and digital signatures.

### Advantages of Hybrid Cryptography

1. Combines speed and security in a single system.
2. Solves the key distribution problem of symmetric cryptography.
3. Faster than using pure asymmetric encryption.
4. Provides secure communication over public networks.
5. Supports digital signatures and authentication.
6. Suitable for large-scale data transmission.
7. Reduces computational overhead.
8. Enhances confidentiality and integrity.
9. Widely used in modern security protocols.
10. Forms the foundation of HTTPS, VPNs, and secure email systems.

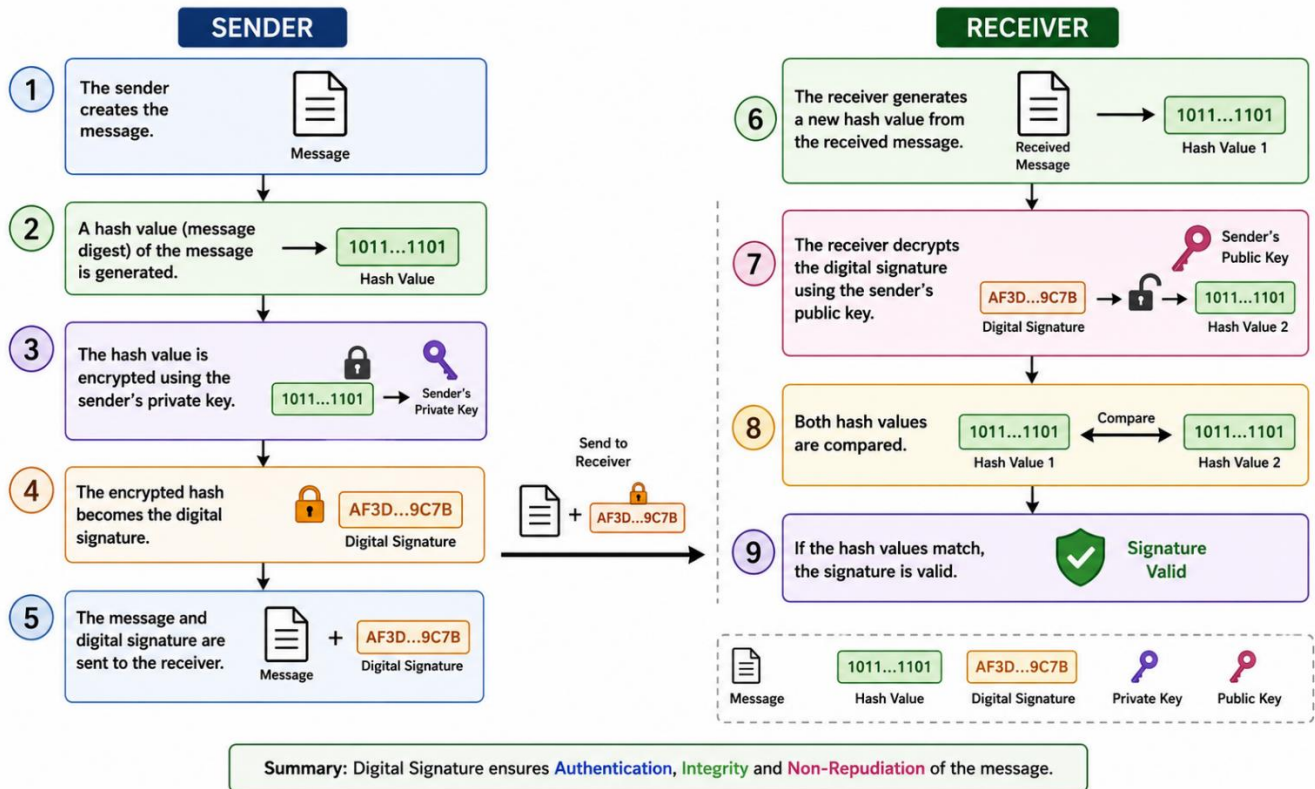
## Digital Signature

A Digital Signature is a cryptographic technique used to verify the authenticity, integrity, and origin of a digital message or document. It is the electronic equivalent of a handwritten signature but provides much higher security. Digital signatures use asymmetric key cryptography, where the sender signs the message using a private key and the receiver verifies it using the corresponding public key.

1. Used to authenticate the sender of a message.
2. Ensures data integrity during transmission.
3. Provides non-repudiation.
4. Based on public key cryptography.
5. Widely used in secure electronic transactions.

## Objectives of Digital Signature

1. **Authentication:** Verifies the identity of the sender.
2. **Integrity:** Ensures that the message has not been altered.
3. **Non-Repudiation:** Prevents the sender from denying the message.
4. **Security:** Protects digital communications from forgery.
5. **Trust:** Establishes confidence in electronic transactions.



## Benefits of Digital Signature

1. Provides strong authentication.
2. Ensures message integrity.
3. Prevents message tampering.
4. Supports non-repudiation.
5. Reduces fraud in electronic transactions.
6. Enables secure online communication.
7. Eliminates the need for physical signatures.
8. Saves time and paperwork.
9. Legally accepted in many countries.
10. Improves trust in digital systems.

## Applications of Digital Signature

1. Electronic document signing.
2. E-Governance services.
3. Online banking transactions.
4. E-Commerce applications.
5. Income tax and GST filing.
6. Software distribution and code signing.
7. Secure email communication.
8. Digital certificates and PKI.
9. Electronic contracts and agreements.
10. Online business transactions.

## Message Digest

A Message Digest is a fixed-length value generated from a message using a hash function. It acts as a unique digital fingerprint of the original data. Even a small change in the message results in a completely different digest. Message digests are widely used in digital signatures, authentication systems, and data integrity verification. **Key Points**

1. Generated using a hash function.
2. Represents the original message in condensed form.
3. Has a fixed length regardless of message size.
4. Used to verify data integrity.
5. Forms the basis of digital signatures.



### Example

Original Message: "Hello"

Message Digest: A1B2C3D4E5F6... (Example Value)

If the message changes to: "hello"

The generated digest will be completely different.

### Characteristics of Message Digest

1. **Fixed Length:** Produces an output of fixed size regardless of input length.
2. **Unique Representation:** Represents the contents of the message uniquely.
3. **One-Way Function:** Original message cannot be recovered from the digest.
4. **Fast Computation:** Can be generated quickly even for large files.
5. **Sensitive to Changes:** Small changes produce completely different digests.
6. **Integrity Checking:** Helps detect unauthorized modifications.
7. **Deterministic:** Same input always produces the same digest.
8. **Collision Resistant:** Difficult to find two messages with the same digest.
9. **Compact:** Requires less storage than the original message.

10. **Secure:** Supports authentication and verification mechanisms.

### Uses of Message Digest

1. Verifying data integrity during transmission.
2. Creating digital signatures.
3. Password storage and authentication.
4. Detecting file tampering.
5. Secure email communication.
6. Software and document verification.
7. Electronic transactions and e-commerce.
8. Blockchain and cryptocurrency systems.
9. Certificate and security protocols.
10. Authentication mechanisms in computer networks.

## Hash Function

A Hash Function is a mathematical algorithm that converts data of any size into a fixed-length value known as a hash value or message digest. It plays a vital role in modern cryptography by ensuring data integrity, authentication, and security. Hash functions are widely used in digital signatures, password protection, blockchain technology, and secure communication systems. **Key Points**

1. Converts input data into a fixed-size output.
2. Produces a unique digital fingerprint of data.
3. Helps detect unauthorized modifications.
4. Used extensively in cryptographic applications.
5. Supports digital signatures and authentication mechanisms.

### Formula

$$H(M) = D$$

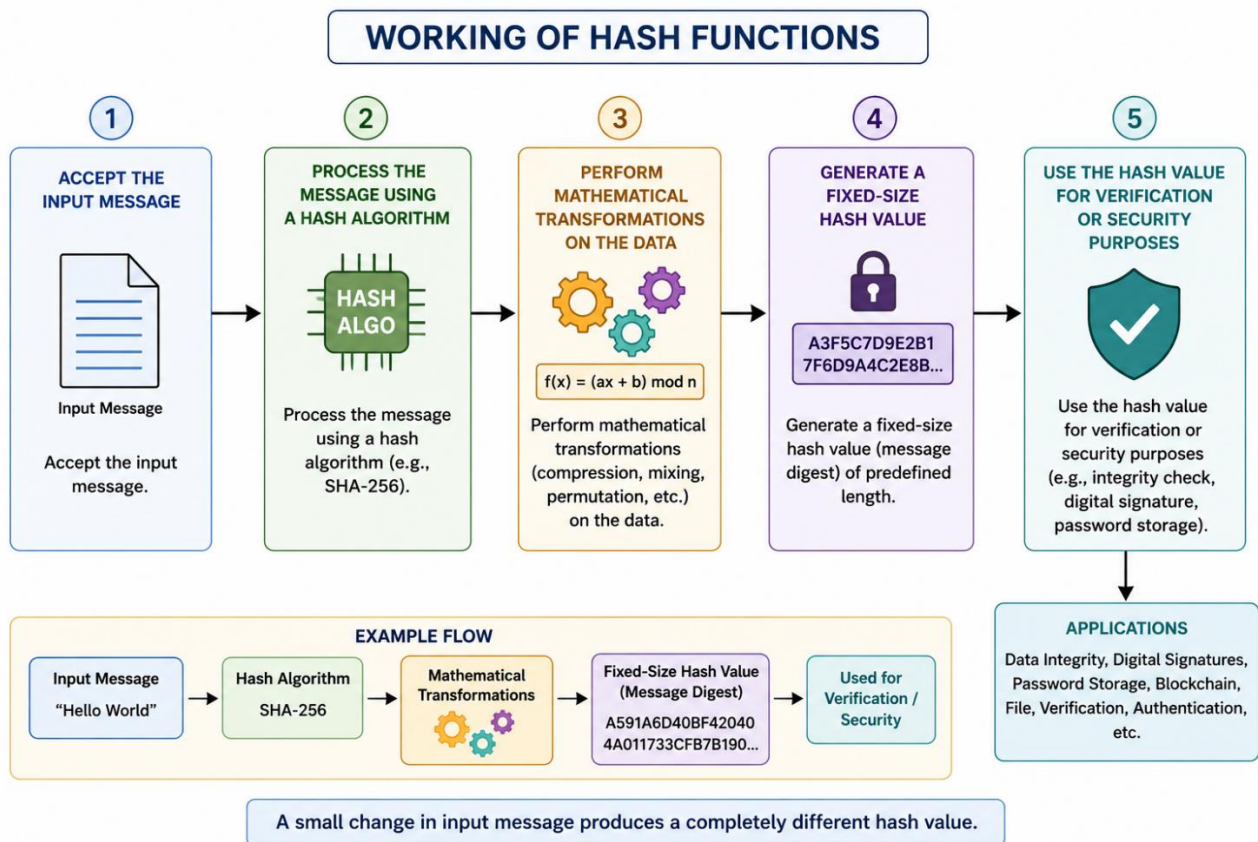
Where:

- H = Hash Function
- M = Input Message
- D = Hash Value (Message Digest)

### Properties of a Good Hash Function

1. **Fixed-Length Output:** Produces a hash value of fixed size regardless of input size.
2. **Deterministic:** The same input always generates the same hash value.
3. **Fast Computation:** Hash values can be generated quickly and efficiently.
4. **One-Way Property (Pre-image Resistance):** It should be computationally impossible to obtain the original message from the hash value.
5. **Collision Resistance:** It should be extremely difficult to find two different messages that generate the same hash value.

6. **Avalanche Effect:** A small change in the input should produce a completely different hash value.
7. **Uniform Distribution:** Hash values should be distributed uniformly to minimize collisions.
8. **Second Pre-image Resistance:** Given a message and its hash, it should be difficult to find another message with the same hash.



### Applications of Hash Functions

1. **Data Integrity Verification:** Used to verify whether data has been modified during transmission or storage.
2. **Digital Signatures:** Hash values are signed instead of entire messages to improve efficiency.
3. **Password Storage:** Passwords are stored as hashes rather than plain text.
4. **File Tampering Detection:** Used to detect unauthorized changes in files and documents.
5. **Secure Email Communication:** Ensures message integrity and authenticity.
6. **Blockchain Technology:** Each block contains hashes linking it to previous blocks.
7. **Software Verification:** Used to verify downloaded software and updates.
8. **Database Indexing:** Helps in fast data retrieval and searching.
9. **Authentication Systems:** Used in login and identity verification processes.
10. **Cryptographic Protocols:** Forms a fundamental component of SSL/TLS, VPNs, and security protocols.

| Aspect        | Hash Function                           | Message Digest                          |
|---------------|-----------------------------------------|-----------------------------------------|
| Definition    | Algorithm used to generate a hash value | Output produced by a hash function      |
| Nature        | Process / Mathematical Function         | Result / Output                         |
| Input         | Accepts data of any length              | Not applicable                          |
| Output        | Produces a message digest               | Fixed-length hash value                 |
| Purpose       | To calculate a hash value               | To represent the original data uniquely |
| Example       | SHA-256, SHA-512, MD5, SHA-1            | A591A6D40BF42040A011733CFB7B190...      |
| Reversibility | One-way function                        | Cannot reveal original message          |

|                 |    |                             |                         |
|-----------------|----|-----------------------------|-------------------------|
| Change<br>Input | in | Produces a different digest | Represents changed data |
|-----------------|----|-----------------------------|-------------------------|

### Key Difference

- **Hash Function** is the algorithm or method used to process data.
- **Message Digest** is the fixed-length output generated by the hash function.

### Example

Input Message



Hash Function (SHA-256)



Message Digest

Thus, the hash function is the process, while the message digest is the result produced by that process.

# MODULE 5: INTERNET SECURITY PROTOCOL, USER AUTHENTICATION

## Contents

|                                          |   |
|------------------------------------------|---|
| Internet Security Protocols .....        | 1 |
| SSL (Secure Socket Layer) Protocol ..... | 1 |
| SSL certificates .....                   | 2 |
| SSL Architecture .....                   | 2 |
| User Authentication .....                | 4 |
| Multi-Factor Authentication (MFA).....   | 4 |
| Biometric Authentication .....           | 5 |
| Password Authentication .....            | 6 |
| Authentication Token .....               | 6 |
| Certificate-Based Authentication.....    | 7 |

## Internet Security Protocols

Internet Security Protocols are a collection of rules and standards used to protect data transmitted across the Internet and computer networks. They ensure that communication remains confidential, authentic, and free from unauthorized modification. **Need for Internet Security Protocols**

1. Protect sensitive information during transmission.
2. Prevent unauthorized access to network resources.
3. Ensure confidentiality of communication.
4. Maintain data integrity.
5. Provide authentication of communicating parties.
6. Support secure e-commerce and online banking.

### Security Services Provided

1. **Confidentiality:** Protects information from unauthorized disclosure through encryption.
2. **Integrity:** Ensures that transmitted data is not modified by attackers.
3. **Authentication:** Verifies the identity of communicating entities.
4. **Non-Repudiation:** Prevents a sender from denying that a message was sent.
5. **Access Control:** Restricts resource access to authorized users only.

### Common Internet Security Protocols

- |           |         |          |
|-----------|---------|----------|
| • SSL/TLS | • IPSec | • PGP    |
| • HTTPS   | • SSH   | • S/MIME |

## SSL (Secure Socket Layer) Protocol

SSL is a cryptographic protocol developed for securing communication over the Internet. Modern systems use TLS (Transport Layer Security), which is the successor to SSL. SSL provides:

- |                  |                   |             |
|------------------|-------------------|-------------|
| • Authentication | • Confidentiality | • Integrity |
|------------------|-------------------|-------------|

**Working Principle:** SSL establishes a secure connection between a client and server before data transmission begins.

## SSL certificates

An SSL Certificate is a bit of code on our web server that provides security for online communications. They safeguard sensitive user data from interception and allow browsers to verify that they are communicating with the legitimate server rather than an imposter. SSL operates right between the Application layer and the Transport layer of the OSI network model

### Why You Need Them

- **Encryption:** They facilitate SSL/TLS encryption, turning unreadable internet traffic into secure code.
- **Trust & Verification:** Browsers display a padlock icon and "HTTPS" to reassure users that the connection is safe.
- **Search Engine Optimization (SEO):** Major search engines give ranking advantages to HTTPS websites.

### How They Work

SSL certificates contain a website's public key, domain details, and a digital signature from a trusted Certificate Authority (CA). When a user connects to a secured site, the browser verifies this signature. Once verified, it creates a secure session, safeguarding any information (like login credentials or credit card numbers) transferred between the user and the server.

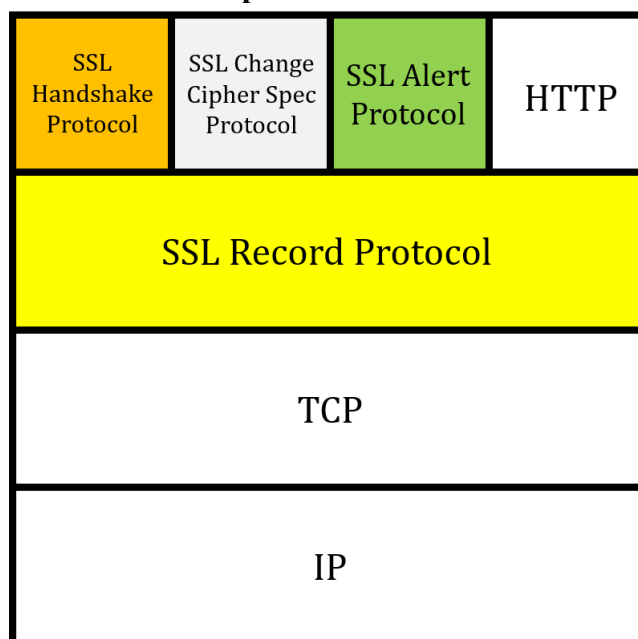
## SSL Architecture

SSL acts as an intermediary layer between application protocols (such as HTTP) and the TCP/IP protocol suite, providing secure communication over the Internet. **Purpose of SSL:**

1. Confidentiality through encryption.
  2. Authentication of communicating parties.
  3. Data integrity verification.
  4. Secure key exchange.
1. **Application Layer (HTTP):** HTTP is an application layer protocol used for web communication.
    - Normally, HTTP sends data in plain text.
    - When SSL is used, HTTP becomes HTTPS.
    - All data exchanged between the browser and server is protected by SSL.

Example:

- HTTP → Insecure
- HTTPS → Secure using SSL/TLS



2. **SSL Handshake Protocol:** The SSL Handshake Protocol is responsible for establishing a secure connection between the client and server.

#### Functions

1. Negotiates SSL/TLS version.
2. Selects encryption algorithms (Cipher Suite).
3. Authenticates the server.
4. Optionally authenticates the client.
5. Establishes session keys.

#### Handshake Steps

1. Client Hello
2. Server Hello
3. Certificate Exchange
4. Key Exchange
5. Session Key Generation
6. Secure Communication Begins

**3. Change Cipher Spec Protocol:** is a simple protocol used during the SSL handshake.

- Notifies the other party that future messages will use the negotiated security parameters.
- Activates the selected encryption and hashing algorithms.
- Marks the transition from an unsecured state to a secured state.

#### Characteristics

- Consists of only one message.
- Sent by both client and server.
- Very small protocol but essential for secure communication.

**4. SSL Alert Protocol:** The Alert Protocol is used to communicate errors and status information.

1. Reports problems during SSL communication.
2. Indicates whether a connection should continue or terminate.
3. Provides warning and fatal alerts.

- Certificate expiration warning.
- Close notification.

2) **Fatal Alert:** Critical errors requiring immediate connection termination.

Examples:

- Invalid certificate.
- Decryption failure.
- Handshake failure.

#### Types of Alerts

1) **Warning Alerts:** on-critical issues.  
Examples:

**5. SSL Record Protocol:** The SSL Record Protocol is the core component of SSL. All SSL messages pass through this protocol before transmission.

#### Functions

1. Fragmentation of data.
2. Compression (optional).
3. Message Authentication Code (MAC) generation.
4. Encryption of data.
5. Secure transmission.

**4. Encryption:** Data and MAC are encrypted using the session key.

**5. Transmission:** Encrypted records are sent through TCP.

#### Importance

The SSL Record Protocol provides:

- Confidentiality
- Integrity
- Authentication

and serves as the foundation for all SSL operations.

#### Working

1. **Fragmentation:** Large messages are divided into smaller blocks.
2. **Compression:** Data may be compressed to reduce size.
3. **MAC Generation:** A Message Authentication Code is generated for integrity verification.

**6. TCP Layer** Transmission Control Protocol (TCP) provides:

- Reliable communication.
- Error detection.
- Flow control.
- Ordered delivery of packets.

SSL uses TCP as its transport mechanism.

**7. IP Layer:** Internet Protocol (IP) is responsible for:

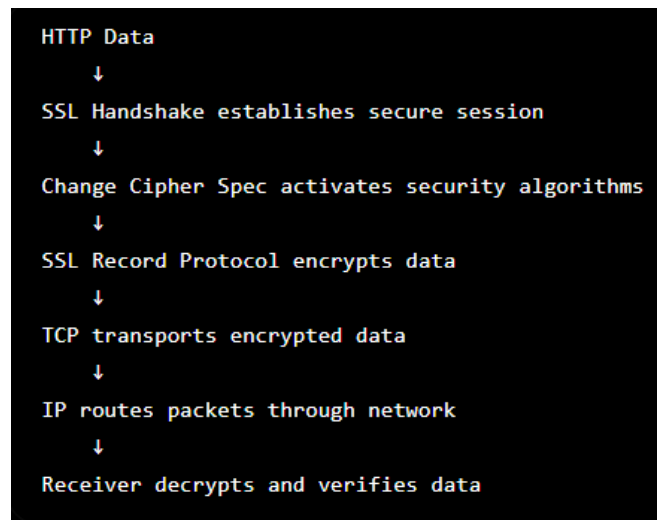
- Addressing.
- Routing packets.
- Delivering packets across networks.

SSL does not directly interact with IP; communication occurs through TCP.

## Working of SSL Architecture (figure ->)

### Advantages of SSL Architecture

1. Provides end-to-end security.
2. Ensures confidentiality through encryption.
3. Verifies identity using digital certificates.
4. Detects message tampering.
5. Protects against eavesdropping attacks.
6. Forms the basis of HTTPS communication.
7. Widely used in e-commerce, online banking, and secure web services.



## User Authentication

User Authentication is the process of verifying the identity of a user before allowing access to a computer system, network, or application. Authentication acts as the first line of defense against unauthorized access and cyberattacks. **Objectives**

1. Verify user identity.
2. Protect confidential resources.
3. Prevent impersonation attacks.
4. Maintain accountability.
5. Support secure communication.

### Authentication Process

1. User submits credentials.
2. System verifies credentials.
3. Authentication server checks validity.
4. Access is granted or denied.

Authentication mechanisms are generally classified according to the type of credential being verified.

### Authentication Factors

1. **Something You Know:** Information known only to the user. Examples: Passwords, PINs, Security Questions
2. **Something You Have:** Physical objects possessed by the user. Examples: Smart Cards, Authentication Tokens, Mobile Phones
3. **Something You Are:** Unique biological characteristics. Examples: Fingerprints, Face Recognition, Iris Recognition
4. **Something You Do:** Behavioral characteristics. Examples: Signature Verification, Typing Rhythm, Voice Pattern
5. **Somewhere You Are** Location-based authentication. Examples: GPS Location, Network Address

## Multi-Factor Authentication (MFA)

MFA combines two or more authentication factors to provide stronger security. Example: Password + OTP/Fingerprint Benefits:

1. Increased security.
2. Reduced risk of credential theft.
3. Better protection against phishing attacks.



# Biometric Authentication

Biometric Authentication identifies individuals based on unique physical or behavioral characteristics. Because biometric traits are unique to each person, they provide a high level of security.

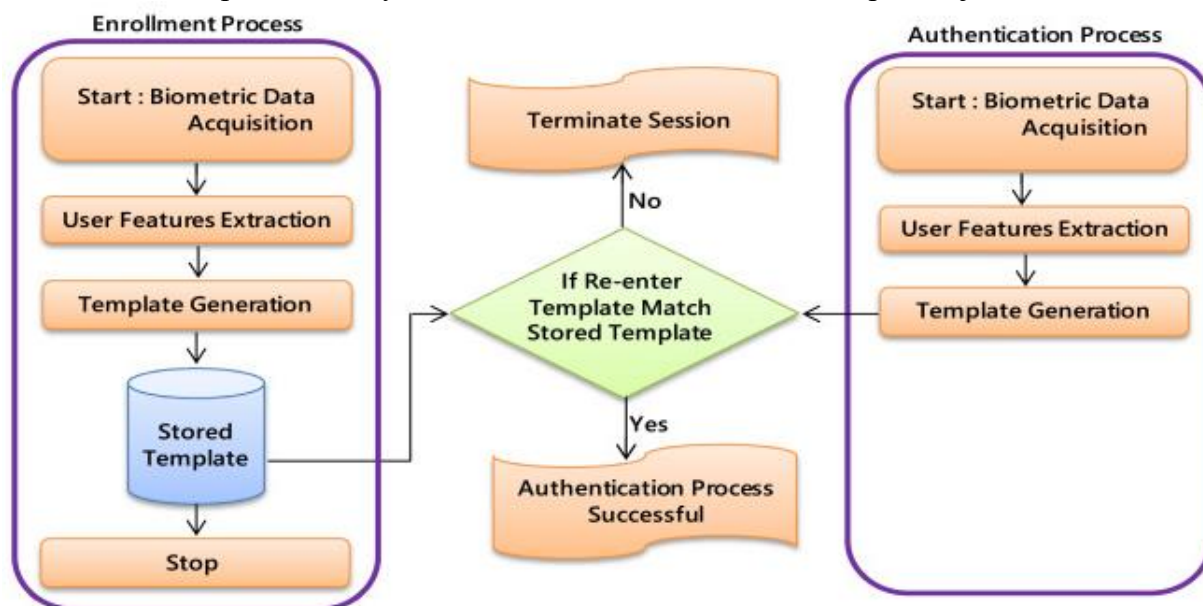
## Biometric Authentication Process

### 1) Enrolment Phase

- Capture biometric sample.
- Extract unique features.
- Create biometric template.
- Store template securely.

### 2) Authentication Phase

- Capture new biometric sample.
- Compare with stored template.
- Calculate matching score.
- Accept or reject user.



## Types of Biometrics

### 1) Physiological Biometrics: Based on physical traits. Examples:

- Fingerprint
- Face Recognition
- Iris Recognition
- Retina Scan
- Palm Print

### 2) Behavioral Biometrics Based on user behavior. Examples:

- Voice Pattern
- Typing Rhythm
- Signature Dynamics
- Gait Recognition

## Performance Measures

1. **FAR (False Acceptance Rate):** Measures the probability of unauthorized users being accepted.
2. **FRR (False Rejection Rate):** Measures the probability of legitimate users being rejected.
3. **EER (Equal Error Rate):** The point where FAR equals FRR. Lower EER indicates a more accurate biometric system.

## Advantages

1. Very high security.
2. Convenient to use.
3. Cannot be forgotten.
4. Difficult to duplicate.

## Disadvantages

1. Privacy concerns.
2. Expensive devices.
3. False acceptance and rejection.
4. Biometrics cannot be changed if compromised.



# Password Authentication

Password Authentication is the most widely used authentication mechanism where a user proves identity by providing a secret password. **Working**

1. User enters username.
2. User enters password.
3. Password hash is generated.
4. Hash is compared with stored hash.
5. Access granted if matched.

**Password Hashing:** Instead of storing passwords directly, systems store hash values.

Common Algorithms:

- SHA-256
- bcrypt
- PBKDF2
- Argon2

Hashing protects passwords even if the database is compromised.

## Characteristics of Strong Passwords

1. Minimum 8–12 characters.
2. Combination of upper and lowercase letters.
3. Includes numbers.
4. Includes special symbols.
5. Avoids dictionary words.
- 3) **Phishing Attack** Tricking users into revealing passwords.
- 4) **Shoulder Surfing:** Observing a user entering credentials.

### Advantages

1. Easy to implement.
2. Low deployment cost.
3. Familiar to users.

## Password Attacks

- 1) **Brute Force Attack:** Trying every possible password combination.
- 2) **Dictionary Attack:** Using a list of common passwords.

### Disadvantages

1. Easy to forget.
2. Vulnerable to attacks.
3. Password reuse problems.

# Authentication Token

An Authentication Token is a physical or software-generated device that produces temporary authentication credentials. Tokens are commonly used in Two-Factor Authentication (2FA).

## Types of Authentication Tokens

- 1) **Hardware Tokens:** Physical devices that generate OTPs. Examples: RSA SecureID, Smart Cards
- 2) **Software Tokens** Applications generating OTPs. Examples: Google Authenticator, Microsoft Authenticator
- 3) **SMS Tokens** One-Time Passwords delivered via SMS.

## Working of Token Authentication

1. User enters username and password.
2. User enters generated OTP.
3. Server verifies OTP.
4. Access is granted.

The OTP changes periodically, making it difficult for attackers to reuse credentials.

### Advantages

1. Strong security.
2. Supports MFA.
3. Difficult to duplicate.

### Disadvantages

1. Additional hardware cost.
2. Token loss issues.
3. Synchronization problems.

# Certificate-Based Authentication

Certificate-Based Authentication verifies identity using a digital certificate issued by a trusted Certificate Authority (CA). It relies on Public Key Infrastructure (PKI).

**Digital Certificate:** A digital certificate contains:

- User identity
- Serial number
- Validity period
- Public key
- Issuer information
- CA signature

**X.509 Certificate:** X.509 is the international standard format for digital certificates.

**Diagram:** X.509 Certificate Structure

**Public Key Infrastructure (PKI):** PKI is a framework that manages digital certificates and public keys. **Components**

- 1) **Certificate Authority (CA):** Issues digital certificates.
- 2) **Registration Authority (RA):** Verifies user identities.
- 3) **Certificate Repository:** Stores certificates.
- 4) **End Users:** Use certificates for authentication.

**Diagram:** PKI Architecture

**Certificate Authentication Process**

1. User presents certificate.
2. Server validates certificate.
3. Server verifies CA signature.
4. Public key is extracted.
5. Authentication succeeds.

**Applications:**

- HTTPS websites
- VPNs
- Enterprise networks

- Government systems

**Advantages**

2. Strong authentication.
3. Difficult to forge.
4. No password management issues.

**Disadvantages**

1. Certificate management overhead.
2. PKI deployment cost.
3. Certificate expiration issues.

# MODULE 6: ELECTRONIC MAIL SECURITY

## Contents

|                                                             |   |
|-------------------------------------------------------------|---|
| Electronic Mail .....                                       | 1 |
| Basics of Mail Security .....                               | 1 |
| Pretty Good Privacy (PGP) .....                             | 2 |
| Web of Trust .....                                          | 3 |
| S/MIME (Secure/Multipurpose Internet Mail Extensions) ..... | 3 |
| MIME .....                                                  | 3 |

## Electronic Mail

Electronic Mail (E-mail) is one of the most widely used communication methods on the Internet. Since e-mails often contain sensitive information such as personal data, financial records, and business documents, protecting them from unauthorized access and modification is essential. Electronic Mail Security provides mechanisms to ensure that messages remain confidential, authentic, and unaltered during transmission.

## Basics of Mail Security

Mail Security refers to the techniques and protocols used to protect e-mail messages against threats such as interception, modification, impersonation, and unauthorized access.

### Security Requirements of E-Mail

- 1. Confidentiality:** Confidentiality ensures that only the intended recipient can read the message contents. If an attacker intercepts the e-mail, the information remains unreadable due to encryption.
- 2. Authentication:** Authentication verifies the identity of the sender and assures the receiver that the message actually originated from the claimed sender.
- 3. Integrity:** Integrity guarantees that the message has not been altered during transmission. Any modification made by an attacker can be detected using hash functions and digital signatures.
- 4. Non-Repudiation:** Non-repudiation prevents the sender from denying that the message was sent. Digital signatures provide proof of origin.
- 5. Availability:** Availability ensures that e-mail services remain accessible to legitimate users whenever required.

### Threats to E-Mail Security

- 1. Eavesdropping:** An attacker secretly intercepts and reads e-mail messages while they are being transmitted.
- 2. Message Modification:** The contents of an e-mail are changed by an attacker before reaching the recipient.
- 3. Spoofing:** An attacker impersonates another user by forging the sender's e-mail address.
- 4. Replay Attack:** Previously captured e-mails are retransmitted to create confusion or gain unauthorized access.
- 5. Malware Attack:** Viruses, worms, and ransomware are distributed through malicious e-mail attachments.
- 6. Phishing:** Fraudulent e-mails trick users into revealing passwords, banking information, or other confidential data.

### Security Mechanisms Used in E-Mail

- Symmetric Key Encryption
- Public Key Encryption
- Digital Signatures
- Hash Functions
- Digital Certificates
- Public Key Infrastructure (PKI)

## Pretty Good Privacy (PGP)

Pretty Good Privacy (PGP) is a popular e-mail security system that provides secure communication by combining symmetric encryption, public-key encryption, compression, and digital signatures. PGP is known as a **hybrid cryptosystem** because it uses both symmetric and asymmetric encryption techniques. **Objectives of PGP**

1. Protect message confidentiality.
2. Verify sender authenticity.
3. Ensure message integrity.
4. Provide non-repudiation.
5. Improve transmission efficiency through compression.

### Services Provided by PGP

1. **Authentication:** PGP uses digital signatures to verify the sender's identity and ensure the message originates from the claimed sender.
2. **Confidentiality:** The message is encrypted using a session key, ensuring that only authorized recipients can read it.
3. **Compression:** Before encryption, the message is compressed to reduce its size and improve transmission efficiency.
4. **E-Mail Compatibility:** PGP converts binary encrypted data into ASCII format using Radix-64 encoding, making it suitable for e-mail transmission.
5. **Segmentation:** Large messages can be divided into smaller segments for easier transmission.

### PGP Encryption Process

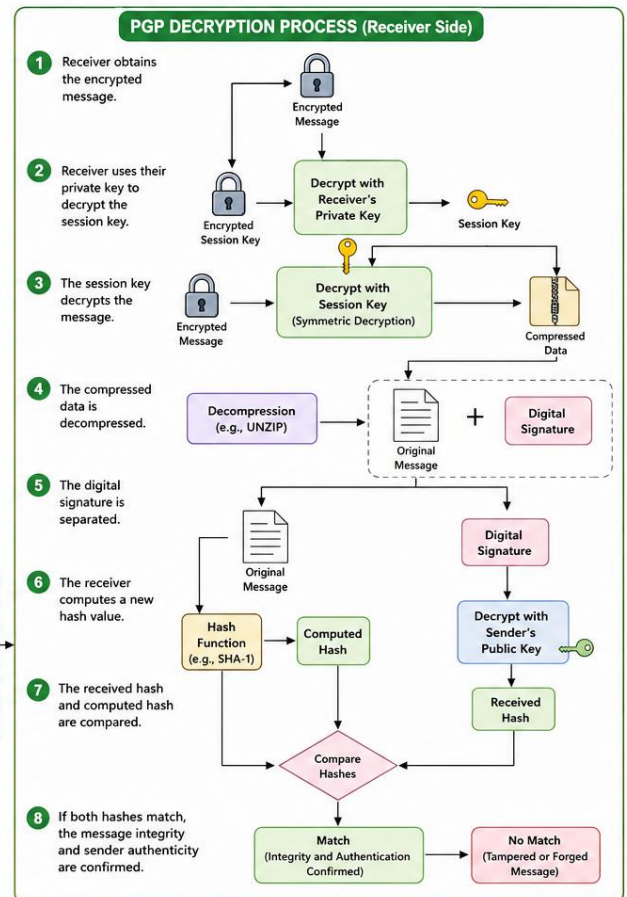
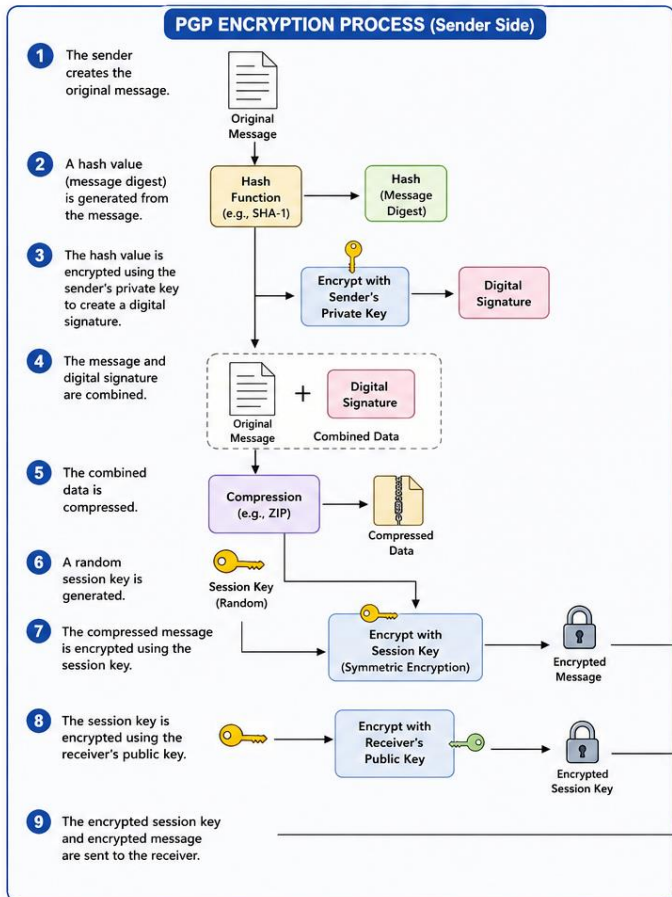
1. The sender creates the original message.
2. A hash value (message digest) is generated from the message.
3. The hash value is encrypted using the sender's private key to create a digital signature.
4. The message and digital signature are combined.
5. The combined data is compressed.
6. A random session key is generated.
7. The compressed message is encrypted using the session key.
8. The session key is encrypted using the receiver's public key.

9. The encrypted session key and encrypted message are sent to the receiver.

### PGP Decryption Process

1. Receiver obtains the encrypted message.
2. Receiver uses their private key to decrypt the session key.
3. The session key decrypts the message.
4. The compressed data is decompressed.
5. The digital signature is separated.
6. The receiver computes a new hash value.
7. The received hash and computed hash are compared.
8. If both hashes match, the message integrity and sender authenticity are confirmed.

## PGP PROCESS – ENCRYPTION AND DECRYPTION



### Advantages of PGP

- Strong security.
- Provides confidentiality and authentication.
- Efficient due to hybrid encryption.
- Supports digital signatures.
- Widely used for secure communication.

### Disadvantages of PGP

- Complex key management.
- Difficult for non-technical users.
- Trust establishment can be challenging.

## Web of Trust

Unlike certificate-based systems, PGP uses a **Web of Trust** model. In this model:

- Users sign each other's public keys.
- Trust is established through recommendations.
- No central authority is required.

This decentralized approach makes PGP flexible but sometimes difficult to manage.

## S/MIME (Secure/Multipurpose Internet Mail Extensions)

S/MIME (Secure Multipurpose Internet Mail Extensions) is a standard for secure electronic mail that uses public key cryptography and digital certificates to provide authentication, integrity, confidentiality, and non-repudiation. It extends the MIME standard by adding security features.

## MIME

MIME (Multipurpose Internet Mail Extensions) is an extension of the traditional e-mail format that allows transmission of:



- Images
- Audio files
- Video files
- Documents
- Multimedia content

S/MIME adds security to MIME messages.

## Features of S/MIME

1. **Confidentiality:** Ensures that only the intended recipient can read the message through encryption.
2. **Authentication:** Verifies the sender's identity using digital certificates.
3. **Integrity:** Detects any unauthorized modification of the message.
4. **Non-Repudiation:** Provides proof that the sender actually sent the message.
5. **Certificate-Based Trust:** Uses Certificate Authorities (CA) to establish trust between users.

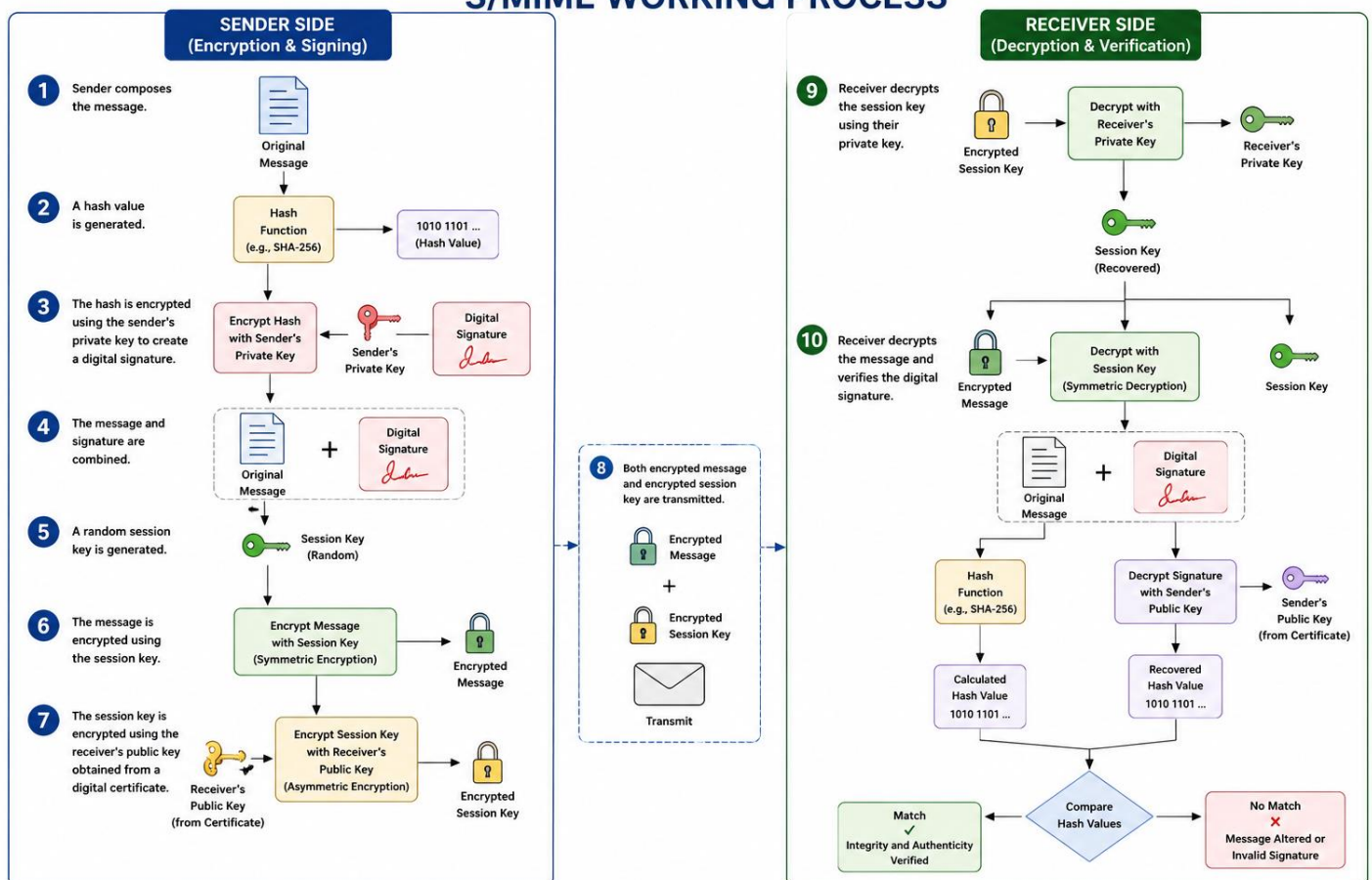
## S/MIME Services

1. **Enveloped Data:** Provides confidentiality by encrypting the entire message.
2. **Signed Data:** Provides authentication and integrity through digital signatures.
3. **Clear Signed Data:** The message remains readable while the signature is attached separately.
4. **Signed and Enveloped Data:** Provides both encryption and digital signature protection.

## S/MIME Working Process

1. Sender composes the message.
2. A hash value is generated.
3. The hash is encrypted using the sender's private key to create a digital signature.
4. The message and signature are combined.

## S/MIME WORKING PROCESS



5. A random session key is generated.
6. The message is encrypted using the session key.
7. The session key is encrypted using the receiver's public key obtained from a digital certificate.
8. Both encrypted message and encrypted session key are transmitted.

9. Receiver decrypts the session key using their private key.
10. Receiver decrypts the message and verifies the digital signature.

#### Advantages of S/MIME

- Industry-standard e-mail security solution.
- Easy integration with modern e-mail clients.
- Uses trusted Certificate Authorities.
- Provides confidentiality, authentication, and integrity.
- Suitable for enterprise environments.

#### Disadvantages of S/MIME

- Requires digital certificates.
- Certificate management can be expensive.
- Depends on Certificate Authorities.

| Feature              | PGP (Pretty Good Privacy)               | S/MIME (Secure/Multipurpose Internet Mail Extensions) |
|----------------------|-----------------------------------------|-------------------------------------------------------|
| Standard Type        | Open standard                           | IETF standard                                         |
| Key Management       | User-managed web of trust               | Certificate Authority (CA)-based trust model          |
| Digital Certificates | Optional                                | Mandatory                                             |
| Trust Model          | Web of Trust                            | Hierarchical PKI (Public Key Infrastructure)          |
| Authentication       | Digital Signature                       | Digital Signature                                     |
| Confidentiality      | Message Encryption                      | Message Encryption                                    |
| Integrity            | Hash Functions and Signatures           | Hash Functions and Signatures                         |
| Encryption Algorithm | RSA, IDEA, CAST, AES, etc.              | RSA, AES, 3DES, etc.                                  |
| Signature Algorithm  | RSA, DSA                                | RSA, DSA, ECDSA                                       |
| Message Format       | Uses PGP message format                 | Uses MIME format                                      |
| Certificate Storage  | Local key ring                          | X.509 Certificates                                    |
| Ease of Deployment   | More complex for organizations          | Easier in enterprise environments                     |
| Email Client Support | Requires PGP-compatible software        | Built into many email clients                         |
| Scalability          | Better for individuals and small groups | Better for large organizations                        |
| Cost                 | Usually free/open source                | May require CA-issued certificates                    |
| Security Management  | User controls trust relationships       | Centralized certificate management                    |
| Main Usage           | Personal secure email communication     | Enterprise and business email security                |
| Examples             | GnuPG, OpenPGP                          | Microsoft Outlook S/MIME, Apple Mail S/MIME           |



# MODULE 7: FIREWALL

## Contents

|                                        |   |
|----------------------------------------|---|
| Firewall .....                         | 1 |
| Types of Firewalls .....               | 2 |
| Firewall Configurations .....          | 3 |
| DMZ (Demilitarized Zone) Network ..... | 4 |
| DMZ Architecture .....                 | 5 |

## Firewall

A firewall is a hardware device, software application, or combination of both that enforces security policies by permitting or denying network traffic. It acts like a network security system that monitors, filters, and controls incoming and outgoing network traffic based on predefined security rules.

It acts as a **barrier between a trusted internal network and an untrusted external network (such as the Internet)**. The primary purpose of a firewall is to prevent unauthorized access while allowing legitimate communication.

### Need for Firewall

1. Protects systems from unauthorized access.
2. Prevents hackers from entering the network.
3. Blocks malicious traffic and cyber attacks.
4. Controls data entering and leaving the network.
5. Protects sensitive information.
6. Enforces organizational security policies.
7. Monitors network activity.

### Objectives of Firewall

1. All traffic between internal and external networks must pass through the firewall.
2. Only authorized traffic should be allowed.
3. The firewall itself must be secure against attacks.

### Working of Firewall

When a packet arrives:

1. Firewall examines source address.
2. Checks destination address.
3. Verifies protocol type (TCP, UDP, ICMP).
4. Examines port numbers.
5. Compares information with security rules.
6. Allows or blocks the packet.

### Advantages of Firewall

1. Prevents unauthorized access.
2. Protects against hackers.
3. Controls network traffic.
4. Monitors network activities.
5. Enforces security policies.
6. Protects sensitive information.
7. Supports logging and auditing.

### Limitations of Firewall

1. Cannot stop attacks originating inside the network.
2. Cannot prevent social engineering attacks.
3. Cannot protect against malware introduced through removable devices.
4. Misconfiguration can create vulnerabilities.
5. Cannot prevent all cyber threats.

### Example

Rule:

- Allow HTTP (Port 80)
- Allow HTTPS (Port 443)
- Block Telnet (Port 23)

Result:

- HTTP traffic → Allowed
- HTTPS traffic → Allowed
- Telnet traffic → Blocked

## Types of Firewalls

1. **Packet Filtering Firewall:** Packet filtering firewall examines individual packets and decides whether to allow or deny them based on predefined rules.

### Parameters Checked

- Source IP Address
- Destination IP Address
- Source Port
- Destination Port
- Protocol Type

### Advantages

1. Fast processing.
2. Simple implementation.
3. Low cost.

### Disadvantages

1. Cannot inspect packet contents.
2. Vulnerable to IP spoofing.
3. Less secure.

2. **Stateful Inspection Firewall:** A stateful firewall tracks the state of active connections and makes decisions based on the context of traffic.

### Working

- Maintains a state table.
- Records active sessions.
- Allows packets belonging to established connections.

### Advantages

- More secure than packet filtering.
- Tracks connection states.
- Better attack prevention.

### Disadvantages

- Higher memory usage.
- More complex.

3. **Application-Level Gateway (Proxy Firewall):** Acts as an intermediary between client and server.

### Working

- Client → Proxy Firewall → Server
- The client never directly communicates with the external server.

### Advantages

- High security.
- Content inspection.
- Hides internal network structure.

### Disadvantages

- Slower performance.
- Higher processing overhead.

4. **Circuit-Level Gateway:** Operates at the Session Layer and verifies TCP handshakes before establishing connections.

### Working

- Validates sessions.
- Does not inspect packet contents.

### Advantages

1. Low overhead.
2. Hides internal addresses.

### Disadvantages

1. Cannot inspect application data.
2. Limited security.

5. **Next Generation Firewall (NGFW):** Advanced firewall that combines traditional firewall functions with additional security features.

### Features

1. Deep Packet Inspection (DPI)
2. Intrusion Prevention System (IPS)
3. Malware Detection
4. Application Awareness
5. URL Filtering

### 6. SSL Inspection

### Advantages

1. Very high security.
2. Real-time threat detection.
3. Protection against modern attacks.

6. **Software Firewall:** Installed on individual computers.

**Examples**

- Windows Defender Firewall
- Linux iptables

**Advantages**

1. Easy installation.

2. Individual device protection.

**Disadvantages**

1. Consumes system resources.
2. Requires maintenance on each device.

7. **Hardware Firewall:** Dedicated physical device placed between network and Internet.

**Advantages**

1. Protects entire network.
2. High performance.
3. Centralized management.

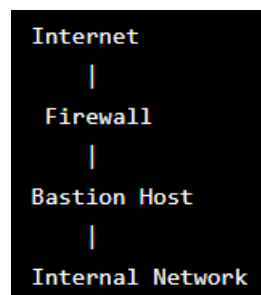
**Disadvantages**

1. Expensive.
2. Requires configuration expertise

## Firewall Configurations

1. **Bastion Host Configuration:** A **Bastion Host** is a highly secured computer that is directly exposed to external networks such as the Internet. It acts as the first point of contact between outside users and the internal network.

- Highly secured operating system.
- Unnecessary services are removed.
- Regular monitoring and updates.
- Strong authentication mechanisms.



**Working**

1. External users first connect to the Bastion Host.
2. The Bastion Host authenticates and processes requests.
3. Only authorized traffic is allowed to access internal resources.
4. The internal network remains hidden from external users.

**Advantages**

1. Simple implementation.
2. Provides controlled access.
3. Protects internal systems from direct exposure.

**Disadvantages**

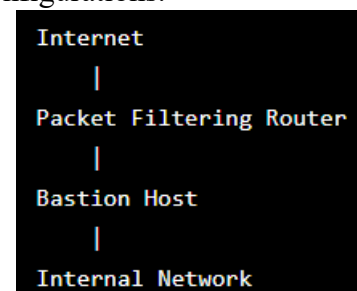
1. Single point of failure.
2. If compromised, security is weakened.
3. Limited protection compared to advanced configurations.

2. **Screened Host Firewall Configuration:** A **Screened Host Firewall System** combines a packet-filtering router (or firewall) with a Bastion Host to provide an additional layer of security.

- Two layers of defense.
- Router filters unwanted traffic.
- Bastion Host provides application-level security.

**Working**

1. The packet-filtering router examines incoming packets.
2. Only permitted traffic reaches the Bastion Host.
3. The Bastion Host performs additional security checks.
4. Approved traffic is forwarded to the internal network.



**Advantages**

- Better security than a simple Bastion Host.
- Multiple filtering mechanisms.
- Reduces unauthorized access.

**Disadvantages**

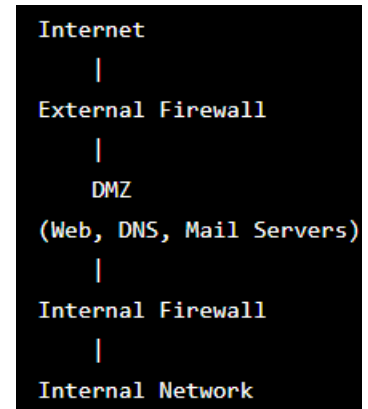
- More complex than a Bastion Host setup.
- Bastion Host remains a critical component.

### 3. Screened Subnet Firewall Configuration: A Screened Subnet Firewall System uses two firewalls to create a separate network segment known as the **DMZ (Demilitarized Zone)**.

- Uses two firewalls.
- Creates an isolated DMZ.
- Provides layered security.

#### Working

1. The external firewall filters Internet traffic.
2. Public servers are placed inside the DMZ.
3. The internal firewall protects the private network.
4. Even if a DMZ server is compromised, attackers cannot directly access the internal network.



#### Advantages

1. Highest level of protection.
2. Public servers are isolated.
3. Internal network remains secure.
4. Suitable for large organizations.

#### Disadvantages

1. Expensive implementation.
2. Complex configuration and management.

## DMZ (Demilitarized Zone) Network

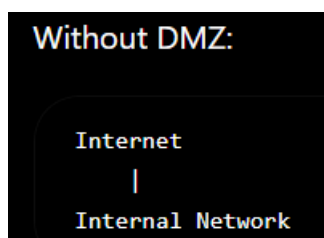
A DMZ (Demilitarized Zone) is a separate network segment positioned between the Internet and the internal network. It contains public-facing servers that must be accessible from the Internet while protecting the internal network.

#### Systems Usually Placed in DMZ

1. Web Servers
2. Mail Servers
3. DNS Servers
4. FTP Servers
5. Proxy Servers

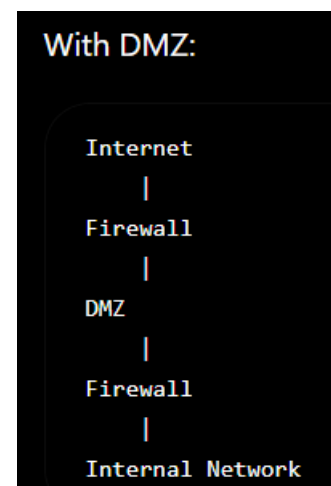
#### Why DMZ is Needed

1. Provides an additional security layer between the Internet and internal network.
2. Protects sensitive internal systems from direct Internet access.
3. Isolates public-facing servers from the private network.
4. Limits damage if a public server is compromised.
5. Reduces the risk of unauthorized access to internal resources.
6. Allows secure hosting of web, mail, and DNS servers.
7. Enables better monitoring and control of network traffic.
8. Supports implementation of stronger security policies.
9. Prevents attackers from directly reaching internal systems.
10. Improves overall network security and reliability.



**Without:** If a public server is compromised, attackers can directly access internal systems.

**With:** Attackers must breach multiple security layers.



### Advantages of DMZ

1. Additional security layer.
2. Protects internal network.
3. Limits damage if public server is compromised.
4. Enables secure public services.

5. Improves network segmentation.

### Disadvantages of DMZ

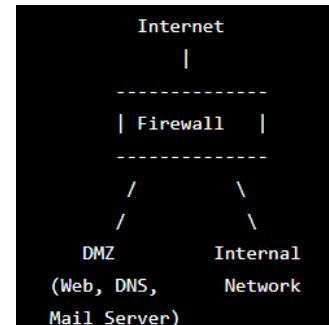
1. Increased complexity.
2. Higher cost.
3. Requires careful management.

## DMZ Architecture

**1. Single DMZ Architecture:** A Single DMZ Architecture uses one firewall with three network interfaces:

- One interface connected to the Internet
- One interface connected to the DMZ
- One interface connected to the Internal Network

The firewall separates the Internet, DMZ, and Internal Network using different security rules.



### Working

1. Internet users access public servers located in the DMZ.
2. The firewall filters traffic entering the DMZ.
3. Internal users can access both the Internet and DMZ.
4. Direct Internet access to the internal network is blocked.

### Advantages

- Less expensive.
- Easy to configure.
- Requires only one firewall.
- Suitable for small organizations.

### Disadvantages

- Single point of failure.
- If the firewall is compromised, the entire network is at risk.
- Lower security compared to Double DMZ.

**2. Double DMZ Architecture:** A Double DMZ Architecture uses **two firewalls** to create a highly secure DMZ between the Internet and the Internal Network. This configuration is also known as a **Screened Subnet Architecture**.

### Working

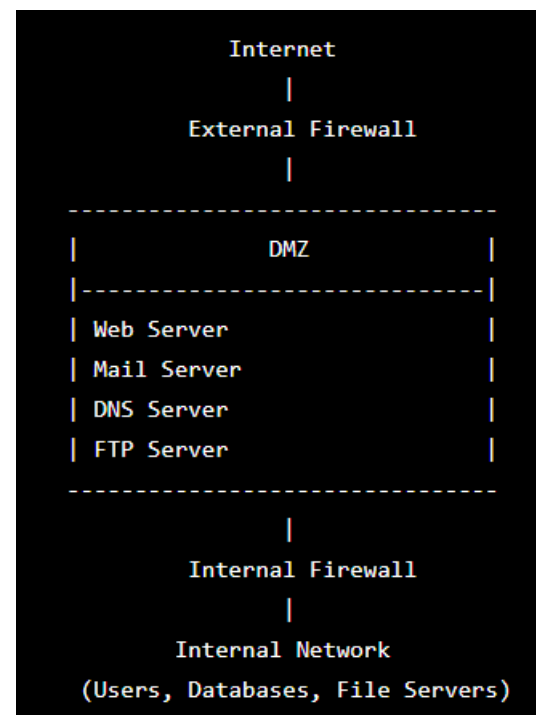
1. Traffic from the Internet first reaches the External Firewall.
2. Allowed traffic enters the DMZ.
3. Public servers provide services from the DMZ.
4. Any traffic moving from the DMZ to the Internal Network must pass through the Internal Firewall.
5. Both firewalls independently inspect and filter traffic.

### Advantages

- Very high security.
- Multiple layers of defense.
- Internal network remains protected even if a DMZ server is compromised.
- Suitable for banks, government agencies, and large enterprises.

### Disadvantages

- Higher cost.
- More complex management.
- Requires additional hardware and maintenance.



| Feature                    | Single DMZ          | Double DMZ          |
|----------------------------|---------------------|---------------------|
| Number of Firewalls        | 1                   | 2                   |
| Security Level             | Medium              | High                |
| Cost                       | Low                 | High                |
| Complexity                 | Low                 | High                |
| Maintenance                | Easy                | Difficult           |
| Single Point of Failure    | Yes                 | No                  |
| Suitable For               | Small Organizations | Large Organizations |
| Protection Against Attacks | Moderate            | Strong              |